

SECURITY ARCHITECTURE V1

Section 1 – Security Architecture Charter & Security Governance Framework

Document ID: SEC-SA-001

Document Name: Security Architecture V1

Section ID: SA-01

Section Title: Security Architecture Charter & Security Governance Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This Security Architecture Charter establishes the security governance foundation, security principles, architectural objectives, accountability structures, and enterprise security requirements governing the Transparent Opportunity Decision Platform (TODP).

The Security Architecture Framework defines how security controls, security services, security monitoring, security governance, risk management, audit activities, and compliance obligations are implemented across TODP to protect platform assets, maintain trust, preserve system integrity, and support enterprise-grade operational maturity.

The framework serves as the authoritative security reference for all platform design, implementation, deployment, operations, governance, audit, and compliance activities.

2. Objectives

The objectives of the Security Architecture Framework are to:

- Establish enterprise-grade security governance.
- Protect confidentiality, integrity, and availability of TODP assets.
- Support transparency and explainability without compromising security.
- Provide defense-in-depth across all platform layers.
- Enable secure operation of all TODP modules.
- Support auditability and compliance readiness.
- Reduce operational and security risks.
- Establish accountability for security decisions.
- Support future enterprise customer security requirements.
- Align with SOC 2 and ISO 27001 readiness objectives.

3. Scope

This framework applies to all TODP assets including:

- Opportunity Module
- Authority Module
- Evidence Module
- Retrieval Module
- Ranking Module
- Recommendation Module
- Governance Module
- Audit Module
- Replay Module

The framework additionally applies to:

- APIs
- Databases
- Search Infrastructure
- Object Storage
- Metadata Repositories
- Audit Repositories
- Monitoring Systems
- Identity Services
- Administrative Interfaces
- Development Environments
- Testing Environments
- Production Environments
- Backup Systems
- Disaster Recovery Systems

4. Security Principles

4.1 Confidentiality

Information shall be protected from unauthorized disclosure.

4.2 Integrity

Information and processing activities shall be protected against unauthorized modification.

4.3 Availability

Systems and services shall remain available according to approved operational objectives.

4.4 Least Privilege

Users, services, and systems shall receive only the permissions required to perform approved responsibilities.

4.5 Zero Trust

Trust shall not be assumed based solely on network location, device location, or prior access.

4.6 Defense in Depth

Security protections shall exist at multiple independent layers.

4.7 Security by Design

Security requirements shall be incorporated into all architecture and engineering activities.

4.8 Auditability

Security-relevant activities shall be logged and independently verifiable.

4.9 Traceability

Security decisions and security events shall maintain traceable records.

4.10 Replay Preservation

Security controls shall support TODP replay and reconstruction requirements.

5. Security Governance Structure

Level 1

Executive Security Sponsor

Responsibilities:

- Security oversight
- Risk acceptance authority
- Executive security governance

Level 2

Security Governance Committee

Responsibilities:

- Security policy approval
- Security review oversight
- Security risk review

Level 3

Security Office

Responsibilities:

- Security architecture ownership
- Security operations governance
- Security reporting

Level 4

Security Domain Owners

Responsibilities:

- Security control ownership
- Domain security oversight

Level 5

Operational Security Teams

Responsibilities:

- Security monitoring
- Security administration
- Security incident response

6. Security Domains

Domain SEC-DOM-001

Identity & Access Security

Domain SEC-DOM-002

Application Security

Domain SEC-DOM-003

Data Security

Domain SEC-DOM-004

Infrastructure Security

Domain SEC-DOM-005

Network Security

Domain SEC-DOM-006

Cloud Security

Domain SEC-DOM-007

Monitoring & Detection

Domain SEC-DOM-008

Audit & Compliance

Domain SEC-DOM-009

Replay Security

Domain SEC-DOM-010

Governance & Risk

7. Security Requirements

SEC-REQ-001

Security requirements shall be defined before implementation.

SEC-REQ-002

Security controls shall be documented.

SEC-REQ-003

Security ownership shall be assigned.

SEC-REQ-004

Security monitoring shall be implemented.

SEC-REQ-005

Security risks shall be evaluated.

SEC-REQ-006

Security events shall be auditable.

SEC-REQ-007

Security controls shall support governance requirements.

SEC-REQ-008

Security controls shall support replay requirements.

8. Security Decision Authority

Operational Security Decisions

Authority:

Security Domain Owner

Security Control Exceptions

Authority:

Security Governance Committee

Critical Security Risk Acceptance

Authority:

Executive Security Sponsor

Emergency Security Response Decisions

Authority:

Security Incident Lead

Enterprise Security Policy Decisions

Authority:

Security Governance Committee

9. Security Architecture Layers

Layer 1

Identity Layer

Purpose:

Authentication and authorization.

Layer 2

Application Layer

Purpose:

Application security enforcement.

Layer 3

Data Layer

Purpose:

Data protection and governance.

Layer 4

Infrastructure Layer

Purpose:

Platform protection.

Layer 5

Monitoring Layer

Purpose:

Detection and response.

Layer 6

Governance Layer

Purpose:

Oversight and assurance.

10. Security Accountability Model

Executive Security Sponsor

Accountable For:

Enterprise security posture.

Security Office

Accountable For:

Security framework operation.

Security Domain Owners

Accountable For:

Assigned security controls.

Engineering Teams

Accountable For:

Secure implementation.

Operations Teams

Accountable For:

Secure operations.

Audit Teams

Accountable For:

Independent verification.

11. Security Risk Governance

All security risks shall:

- Be documented.
- Have assigned owners.
- Be evaluated using approved methodologies.
- Be periodically reviewed.
- Support audit verification.
- Maintain remediation plans where applicable.

12. Security Architecture Constraints

SA-CON-001

Security controls shall not compromise audit integrity.

SA-CON-002

Security controls shall preserve traceability requirements.

SA-CON-003

Security controls shall preserve replay capability.

SA-CON-004

Security controls shall support enterprise scalability.

SA-CON-005

Security architecture shall support modular service boundaries.

SA-CON-006

Security controls shall support future compliance expansion.

13. Security Metrics

SEC-MET-001

Security Control Coverage

Target: $\geq 95\%$

SEC-MET-002

Security Ownership Coverage

Target: 100%

SEC-MET-003

Security Review Completion

Target: $\geq 95\%$

SEC-MET-004

Critical Security Risk Review Compliance

Target: 100%

SEC-MET-005

Security Monitoring Coverage

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-001

Security governance activities shall be auditable.

AUD-SEC-002

Security ownership assignments shall be verifiable.

AUD-SEC-003

Security decisions shall maintain evidence.

AUD-SEC-004

Security reviews shall be documented.

AUD-SEC-005

Security metrics shall support independent verification.

AUD-SEC-006

Security exceptions shall be retained.

15. Compliance Requirements

This framework supports alignment with:

- SOC 2 Security Criteria
- SOC 2 Availability Criteria

- SOC 2 Confidentiality Criteria
- ISO 27001 Governance Controls
- ISO 27001 Risk Management Controls
- ISO 27002 Security Architecture Practices
- Enterprise Procurement Assessments
- Customer Security Reviews

16. Security Documentation Requirements

The following security artifacts shall be maintained:

- Security Architecture
- Security Standards
- Security Procedures
- Security Runbooks
- Security Risk Register
- Security Incident Records
- Security Review Reports
- Security Audit Reports

17. Governance Rules

SEC-GOV-001

Security controls shall be approved before production deployment.

SEC-GOV-002

Security ownership shall be documented.

SEC-GOV-003

Security exceptions shall be formally approved.

SEC-GOV-004

Security reviews shall be periodically performed.

SEC-GOV-005

Security controls shall remain auditable.

SEC-GOV-006

Security architecture shall support governance and audit requirements.

18. Traceability

Related Documents

PRD V1

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

TEST SPEC V1

RTM V1

ADR V1

API SPEC V1

DATA GOVERNANCE V1

Mapped Modules

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

19. Risk Considerations

Primary Risks:

- Unauthorized access
- Data compromise
- Security control failures

- Compliance deficiencies
- Monitoring gaps
- Governance failures

Mitigation Controls:

- Defense-in-depth architecture
- Security governance reviews
- Continuous monitoring
- Risk management controls
- Audit verification
- Executive oversight

20. Security Architecture Vision

TODP shall operate under a security-first architecture model where all platform services, data assets, governance processes, audit functions, and replay capabilities are protected through layered, auditable, traceable, and enterprise-grade security controls aligned with the principles of transparency, explainability, governance, auditability, and replayability.

21. Dependencies

Dependent Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

RTM V1

DATA GOVERNANCE V1

Dependent Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

22. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Major architecture changes
- Security incidents
- Regulatory changes
- Enterprise customer requirements

- Material risk changes

23. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Engineering Leadership

Operations Leadership

Audit Office

24. Approval Authority

Approved By:

Security Governance Committee

Final Approval Authority:

Executive Security Sponsor

25. Section Summary

This section establishes the Security Architecture Charter and Security Governance Framework for TODP, defining security principles, governance structures, accountability models, security domains, architectural constraints, compliance alignment, audit obligations, metrics, ownership responsibilities, and enterprise security objectives necessary to support a secure, auditable, traceable, explainable, and enterprise-ready decision-support platform.

SECURITY ARCHITECTURE V1

Section 2 – Security Principles, Security Objectives & Architectural Security Standards

Document ID: SEC-SA-002

Document Name: Security Architecture V1

Section ID: SA-02

Section Title: Security Principles, Security Objectives & Architectural Security Standards

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the foundational security principles, security objectives, and architectural security standards governing the design, implementation, operation, maintenance, and evolution of TODP.

These principles establish mandatory security requirements that apply across all platform modules, services, infrastructure components, integrations, governance processes, audit mechanisms, and replay capabilities.

2. Objectives

The objectives of this section are to:

- Establish consistent security architecture principles.
- Define security expectations for all platform components.
- Support secure-by-design implementation.
- Enable scalable enterprise security controls.
- Protect platform assets and information.
- Support auditability and compliance.
- Preserve transparency and explainability objectives.
- Support long-term enterprise growth.

3. Security Design Principles

SA-PRIN-001

Security by Design

Security requirements shall be incorporated into all architecture decisions before implementation.

SA-PRIN-002

Least Privilege

Access permissions shall be restricted to the minimum required.

SA-PRIN-003

Defense in Depth

Multiple independent security controls shall protect critical assets.

SA-PRIN-004

Zero Trust

All access requests shall be verified regardless of origin.

SA-PRIN-005

Fail Secure

Security failures shall default to secure states.

SA-PRIN-006

Separation of Duties

Critical operations shall require separation of authority.

SA-PRIN-007

Traceability

Security activities shall generate traceable records.

SA-PRIN-008

Auditability

Security decisions shall be independently verifiable.

SA-PRIN-009

Replay Preservation

Security controls shall preserve replay capability.

SA-PRIN-010

Scalability

Security controls shall support enterprise growth.

4. Architectural Security Objectives

SEC-OBJ-001

Protect platform confidentiality.

SEC-OBJ-002

Protect platform integrity.

SEC-OBJ-003

Maintain platform availability.

SEC-OBJ-004

Support audit readiness.

SEC-OBJ-005

Support governance operations.

SEC-OBJ-006

Support replay operations.

SEC-OBJ-007

Protect customer trust.

SEC-OBJ-008

Support future compliance programs.

5. Security Standards Framework

Security standards shall govern:

- Identity Security
- Access Security
- Application Security
- Data Security
- Infrastructure Security
- Network Security
- Monitoring Security
- Audit Security
- Replay Security
- Governance Security

6. Architectural Requirements

SEC-ARCH-001

Security controls shall be documented.

SEC-ARCH-002

Security services shall support high availability.

SEC-ARCH-003

Security services shall support centralized monitoring.

SEC-ARCH-004

Security controls shall support evidence generation.

SEC-ARCH-005

Security controls shall support risk management.

SEC-ARCH-006

Security controls shall support incident response.

7. Governance Rules

SEC-GOV-007

Security principles are mandatory.

SEC-GOV-008

Architecture reviews shall validate security alignment.

SEC-GOV-009

Security deviations require approval.

SEC-GOV-010

Security standards shall be periodically reviewed.

8. Metrics

SEC-MET-006

Architecture Security Compliance

Target: $\geq 95\%$

SEC-MET-007

Security Standard Adoption

Target: 100%

SEC-MET-008

Security Review Completion

Target: $\geq 95\%$

9. Audit Requirements

AUD-SEC-007

Security principle compliance shall be auditable.

AUD-SEC-008

Architecture review evidence shall be retained.

AUD-SEC-009

Security deviations shall be documented.

10. Compliance Requirements

Supports:

- SOC 2 Security
- ISO 27001 Security Architecture
- ISO 27002 Secure Design
- Enterprise Security Reviews

11. Section Summary

This section establishes TODP security principles, architectural objectives, and mandatory security standards governing all platform components and security decisions.

Document ID: SEC-SA-003

Document Name: Security Architecture V1

Section ID: SA-03

Section Title: Security Domain Architecture & Security Control Model

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the security domains, security architecture layers, and control model used to secure TODP.

The framework establishes how security controls are organized, deployed, governed, monitored, and validated across all platform services.

2. Objectives

The objectives are to:

- Define security domains.
- Establish layered security architecture.
- Standardize security control deployment.
- Support governance and audit requirements.
- Enable scalable security management.

3. Security Domain Model

Domain SA-DOM-001

Identity Security

Purpose:

Authentication and identity assurance.

Domain SA-DOM-002

Authorization Security

Purpose:

Permission management and access governance.

Domain SA-DOM-003

Application Security

Purpose:

Secure application execution.

Domain SA-DOM-004

Data Security

Purpose:

Protection of governed data assets.

Domain SA-DOM-005

Infrastructure Security

Purpose:

Protection of computing resources.

Domain SA-DOM-006

Network Security

Purpose:

Protection of communication pathways.

Domain SA-DOM-007

Monitoring Security

Purpose:

Detection and visibility.

Domain SA-DOM-008

Audit Security

Purpose:

Protection of audit integrity.

Domain SA-DOM-009

Replay Security

Purpose:

Protection of replay processes.

Domain SA-DOM-010

Governance Security

Purpose:

Protection of governance operations.

4. Security Layer Architecture

Layer 1

Identity Layer

Controls:

- Authentication
- Identity verification
- Credential protection

Layer 2

Access Layer

Controls:

- Authorization
- Role enforcement
- Privilege management

Layer 3

Application Layer

Controls:

- Input validation
- Session protection
- API protection

Layer 4

Data Layer

Controls:

- Encryption
- Data integrity
- Data governance controls

Layer 5

Infrastructure Layer

Controls:

- Host protection
- Environment hardening
- Resource isolation

Layer 6

Monitoring Layer

Controls:

- Logging
- Alerting
- Detection

Layer 7

Governance Layer

Controls:

- Security oversight
- Risk management
- Compliance validation

5. Security Control Categories

Preventive Controls

Purpose:

Prevent security incidents.

Detective Controls

Purpose:

Detect security events.

Corrective Controls

Purpose:

Restore secure operation.

Compensating Controls

Purpose:

Reduce risk when primary controls cannot be implemented.

6. Security Control Requirements

SEC-CTRL-001

Controls shall have assigned owners.

SEC-CTRL-002

Controls shall be documented.

SEC-CTRL-003

Controls shall be monitored.

SEC-CTRL-004

Controls shall support audit verification.

SEC-CTRL-005

Controls shall support risk management.

SEC-CTRL-006

Controls shall support compliance objectives.

7. Security Control Ownership

Security Office

Owns:

Enterprise security controls.

Domain Security Owners

Own:

Domain-specific controls.

Engineering Teams

Own:

Implementation controls.

Operations Teams

Own:

Operational controls.

Audit Team

Validates:

Control effectiveness.

8. Metrics

SEC-MET-009

Control Ownership Coverage

Target: 100%

SEC-MET-010

Control Monitoring Coverage

Target: $\geq 95\%$

SEC-MET-011

Control Effectiveness Validation

Target: $\geq 95\%$

9. Audit Requirements

AUD-SEC-010

Control inventories shall be auditable.

AUD-SEC-011

Control ownership shall be verifiable.

AUD-SEC-012

Control testing evidence shall be retained.

10. Architectural Constraints

SA-CON-007

Security controls shall remain modular.

SA-CON-008

Controls shall support service isolation.

SA-CON-009

Controls shall support future expansion.

11. Compliance Requirements

Supports:

- SOC 2 Security
- ISO 27001 Controls
- ISO 27002 Security Operations
- Enterprise Security Reviews

12. Section Summary

This section establishes TODP security domains, layered security architecture, security control categories, ownership structures, monitoring requirements, audit obligations, and enterprise security control governance.

SECURITY ARCHITECTURE V1

Section 4 – Identity & Authentication Security Architecture

Document ID: SEC-SA-004

Document Name: Security Architecture V1

Section ID: SA-04

Section Title: Identity & Authentication Security Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Identity and Authentication Security Architecture for TODP.

The architecture establishes the controls, trust boundaries, authentication mechanisms, identity lifecycle requirements, governance controls, monitoring requirements, audit obligations, and security standards required to verify identities before access is granted to TODP resources.

The architecture supports the platform principles of transparency, explainability, traceability, governance, auditability, and replayability while maintaining enterprise-grade security.

2. Objectives

- Establish trusted identity verification mechanisms.
- Prevent unauthorized access.
- Support enterprise authentication requirements.
- Enable centralized identity governance.
- Support audit and compliance requirements.
- Enable secure user and service authentication.
- Support future enterprise federation requirements.
- Maintain accountability for identity activities.

3. Scope

Applies to:

- End Users
- Administrators
- Governance Users
- Audit Users
- Service Accounts
- API Clients
- Internal Services
- External Integrations

Applies across:

- Opportunity
- Authority

- Evidence
- Retrieval
- Ranking
- Recommendation
- Governance
- Audit
- Replay

4. Identity Security Principles

SEC-ID-001

Every identity shall be uniquely identifiable.

SEC-ID-002

Authentication shall occur before authorization.

SEC-ID-003

Identity verification shall be centrally governed.

SEC-ID-004

Identity events shall be auditable.

SEC-ID-005

Identity controls shall support least privilege.

SEC-ID-006

Identity systems shall support traceability.

5. Identity Architecture Components

Identity Provider Layer

Responsibilities:

- Authentication
- Identity verification
- Credential validation

Identity Governance Layer

Responsibilities:

- Account lifecycle management
- Role assignment
- Access reviews

Authentication Layer

Responsibilities:

- Login verification
- Session establishment

Monitoring Layer

Responsibilities:

- Identity event monitoring
- Authentication analytics

Audit Layer

Responsibilities:

- Authentication evidence
- Identity traceability

6. Authentication Requirements

SEC-AUTH-001

All users shall authenticate before access.

SEC-AUTH-002

Administrative accounts shall require MFA.

SEC-AUTH-003

Privileged accounts shall require enhanced authentication.

SEC-AUTH-004

Service identities shall use managed credentials.

SEC-AUTH-005

Authentication events shall be logged.

SEC-AUTH-006

Authentication failures shall be monitored.

7. Identity Lifecycle Management

Lifecycle Stages:

- Identity Creation
- Identity Verification
- Identity Activation
- Identity Modification
- Identity Suspension

- Identity Revocation
- Identity Archival

All lifecycle events shall be documented and auditable.

8. Service Identity Security

SEC-SVC-001

Service accounts shall be uniquely identifiable.

SEC-SVC-002

Shared service credentials are prohibited.

SEC-SVC-003

Service credentials shall be protected.

SEC-SVC-004

Service account activity shall be monitored.

SEC-SVC-005

Service identity ownership shall be documented.

9. Session Security Requirements

SEC-SES-001

Sessions shall be authenticated.

SEC-SES-002

Session expiration controls shall be enforced.

SEC-SES-003

Session activity shall be monitored.

SEC-SES-004

Session termination shall be supported.

SEC-SES-005

Session records shall support audits.

10. Governance Rules

SEC-GOV-011

Identity ownership shall be assigned.

SEC-GOV-012

Authentication controls shall be mandatory.

SEC-GOV-013

Identity events shall be auditable.

SEC-GOV-014

Privileged identities shall receive enhanced monitoring.

SEC-GOV-015

Identity controls shall support replay requirements.

11. Metrics

SEC-MET-012

MFA Coverage

Target: 100% Administrative Accounts

SEC-MET-013

Identity Ownership Coverage

Target: 100%

SEC-MET-014

Authentication Logging Coverage

Target: 100%

SEC-MET-015

Privileged Identity Review Compliance

Target: $\geq 95\%$

12. Audit Requirements

AUD-SEC-013

Identity inventories shall be auditable.

AUD-SEC-014

Authentication records shall be retained.

AUD-SEC-015

Identity lifecycle activities shall be reviewable.

AUD-SEC-016

Service account ownership shall be verifiable.

13. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Confidentiality
- ISO 27001 Access Control
- ISO 27002 Identity Management

14. Architectural Constraints

SA-CON-010

Identity services shall be centralized.

SA-CON-011

Authentication systems shall support audit logging.

SA-CON-012

Identity controls shall support future federation requirements.

SA-CON-013

Authentication controls shall preserve replay capability.

15. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

API SPEC V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

16. Risk Considerations

Primary Risks:

- Credential compromise
- Account takeover
- Unauthorized access
- Identity spoofing

Mitigation Controls:

- MFA
- Identity governance
- Monitoring
- Audit logging

17. Section Summary

This section establishes the TODP Identity and Authentication Security Architecture, defining identity controls, authentication mechanisms, lifecycle governance, monitoring requirements, audit obligations, compliance alignment, and architectural constraints.

SECURITY ARCHITECTURE V1

Section 5 – Authorization, Access Control & Privileged Access Security Architecture

Document ID: SEC-SA-005

Document Name: Security Architecture V1

Section ID: SA-05

Section Title: Authorization, Access Control & Privileged Access Security Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Authorization, Access Control, and Privileged Access Security Architecture governing access to TODP resources.

The architecture establishes how permissions are granted, reviewed, monitored, enforced, and revoked across all TODP services and modules.

2. Objectives

- Enforce least privilege.
- Control access to platform resources.
- Protect sensitive information.
- Enable centralized authorization governance.
- Support enterprise access management.
- Reduce insider risk.

- Support audit readiness.
- Maintain accountability.

3. Scope

Applies to:

- User Access
- Administrative Access
- Service Access
- API Access
- Database Access
- Governance Access
- Audit Access
- Replay Access

4. Access Control Principles

SEC-ACC-001

Default deny shall be enforced.

SEC-ACC-002

Least privilege shall be enforced.

SEC-ACC-003

Need-to-know principles shall apply.

SEC-ACC-004

Access shall be approved before activation.

SEC-ACC-005

Access shall be periodically reviewed.

SEC-ACC-006

Access activities shall be auditable.

5. Authorization Model

Authorization Layer 1

Role-Based Access Control (RBAC)

Purpose:

Assign permissions through approved roles.

Authorization Layer 2

Resource Authorization

Purpose:

Restrict access to governed resources.

Authorization Layer 3

Administrative Authorization

Purpose:

Protect privileged operations.

Authorization Layer 4

Governance Authorization

Purpose:

Protect governance decisions and controls.

6. Privileged Access Security

SEC-PAM-001

Privileged accounts shall be identified.

SEC-PAM-002

Privileged access shall require approval.

SEC-PAM-003

Privileged activity shall be monitored.

SEC-PAM-004

Privileged access shall undergo periodic review.

SEC-PAM-005

Emergency privileged access shall be documented.

7. Access Lifecycle Management

Stages:

- Access Request
- Approval
- Provisioning
- Review
- Modification
- Revocation

- Archival

All stages shall maintain audit evidence.

8. Access Review Requirements

SEC-REV-001

Privileged access reviews shall occur quarterly.

SEC-REV-002

Critical access reviews shall occur quarterly.

SEC-REV-003

Inactive accounts shall be reviewed.

SEC-REV-004

Access review evidence shall be retained.

9. Segregation of Duties

SEC-SOD-001

Approval and implementation responsibilities shall be separated.

SEC-SOD-002

Audit and administration duties shall remain independent.

SEC-SOD-003

Governance and operational approvals shall remain independent.

10. Governance Rules

SEC-GOV-016

Unauthorized access is prohibited.

SEC-GOV-017

Access approvals shall be documented.

SEC-GOV-018

Privileged activities shall be monitored.

SEC-GOV-019

Access reviews shall be mandatory.

SEC-GOV-020

Access controls shall support replay and audit requirements.

11. Metrics

SEC-MET-016

Access Review Completion

Target: $\geq 95\%$

SEC-MET-017

Privileged Access Review Compliance

Target: $\geq 95\%$

SEC-MET-018

Unauthorized Access Incidents

Target: 0

SEC-MET-019

Access Approval Compliance

Target: 100%

12. Audit Requirements

AUD-SEC-017

Access approvals shall be auditable.

AUD-SEC-018

Privileged activities shall be reviewable.

AUD-SEC-019

Access review records shall be retained.

AUD-SEC-020

Segregation of duties controls shall be verifiable.

13. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Confidentiality

- ISO 27001 Access Control
- ISO 27002 Privileged Access Management

14. Architectural Constraints

SA-CON-014

Authorization services shall be centralized.

SA-CON-015

Access controls shall support service isolation.

SA-CON-016

Authorization events shall generate audit records.

SA-CON-017

Access governance shall support future enterprise expansion.

15. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

API SPEC V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

16. Risk Considerations

Primary Risks:

- Excessive permissions
- Privilege abuse
- Unauthorized access
- Segregation failures

Mitigation Controls:

- RBAC
- Access reviews
- Privileged monitoring
- Governance oversight

17. Section Summary

This section establishes the TODP Authorization, Access Control, and Privileged Access Security Architecture, defining authorization models, privileged access controls, lifecycle management processes, governance requirements, audit obligations, compliance alignment, and architectural constraints.

SECURITY ARCHITECTURE V1

Section 6 – Data Security Architecture, Encryption & Information Protection Framework

Document ID: SEC-SA-006

Document Name: Security Architecture V1

Section ID: SA-06

Section Title: Data Security Architecture, Encryption & Information Protection Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Data Security Architecture, Encryption Framework, and Information Protection Model for TODP.

The architecture establishes the security controls required to protect Opportunity, Authority, Evidence, Retrieval, Ranking, Recommendation, Governance, Audit, and Replay data throughout its lifecycle.

The framework ensures confidentiality, integrity, availability, traceability, auditability, and replayability of all governed information assets.

2. Objectives

- Protect information assets throughout their lifecycle.
- Enforce classification-based protection controls.
- Secure data at rest and in transit.
- Preserve data integrity.
- Protect sensitive and restricted information.
- Support governance and audit requirements.
- Support enterprise customer security requirements.
- Maintain compliance readiness.

3. Scope

Applies to:

- Operational Data
- Metadata
- Governance Data
- Audit Records

- Replay Records
- Configuration Data
- Monitoring Data
- Backup Data
- Archive Data
- Integration Data

4. Information Protection Principles

SEC-DATA-001

Information shall be classified before operational use.

SEC-DATA-002

Information protection shall align with classification levels.

SEC-DATA-003

Sensitive information shall receive enhanced protection.

SEC-DATA-004

Information integrity shall be preserved.

SEC-DATA-005

Protection controls shall support audit requirements.

SEC-DATA-006

Protection controls shall preserve replay capability.

5. Data Classification Security Controls

PUBLIC

Required Controls:

- Integrity protection
- Availability protection

INTERNAL

Required Controls:

- Access control
- Monitoring controls

CONFIDENTIAL

Required Controls:

- Encryption

- Enhanced authorization
- Audit logging
- Periodic review

RESTRICTED

Required Controls:

- Enhanced encryption
- Enhanced monitoring
- Enhanced governance review
- Restricted access controls

6. Encryption Architecture

Encryption Domain SEC-ENC-001

Data At Rest Protection

Purpose:

Protect stored information.

Encryption Domain SEC-ENC-002

Data In Transit Protection

Purpose:

Protect data movement.

Encryption Domain SEC-ENC-003

Key Management

Purpose:

Protect encryption materials.

Encryption Domain SEC-ENC-004

Secret Management

Purpose:

Protect credentials and secrets.

7. Encryption Requirements

SEC-ENC-001

Confidential and Restricted information shall be encrypted at rest.

SEC-ENC-002

Sensitive communications shall be encrypted in transit.

SEC-ENC-003

Encryption keys shall be protected.

SEC-ENC-004

Key access shall be restricted.

SEC-ENC-005

Key usage shall be auditable.

SEC-ENC-006

Encryption governance shall be documented.

8. Data Integrity Controls

SEC-INT-001

Critical records shall support integrity validation.

SEC-INT-002

Audit records shall be protected from unauthorized modification.

SEC-INT-003

Replay records shall maintain integrity protection.

SEC-INT-004

Integrity violations shall trigger investigation.

SEC-INT-005

Integrity monitoring evidence shall be retained.

9. Data Loss Prevention Requirements

SEC-DLP-001

Unauthorized disclosure shall be prevented.

SEC-DLP-002

Sensitive exports shall be governed.

SEC-DLP-003

Data movement shall be monitored.

SEC-DLP-004

Restricted data sharing shall require approval.

SEC-DLP-005

DLP activities shall support audit reviews.

10. Backup Security Requirements

SEC-BKP-001

Backups shall be protected.

SEC-BKP-002

Backup access shall be restricted.

SEC-BKP-003

Backup integrity shall be verified.

SEC-BKP-004

Backup recovery testing shall be performed.

11. Governance Rules

SEC-GOV-021

Sensitive information shall be classified.

SEC-GOV-022

Encryption requirements shall be mandatory.

SEC-GOV-023

Integrity controls shall be enforced.

SEC-GOV-024

Protected information access shall be monitored.

SEC-GOV-025

Data security controls shall support replay requirements.

12. Metrics

SEC-MET-020

Encryption Compliance

Target: 100%

SEC-MET-021

Protected Data Coverage

Target: 100%

SEC-MET-022

Backup Protection Compliance

Target: $\geq 95\%$

SEC-MET-023

Integrity Validation Success Rate

Target: $\geq 99\%$

13. Audit Requirements

AUD-SEC-021

Encryption controls shall be auditable.

AUD-SEC-022

Key management controls shall be reviewable.

AUD-SEC-023

Integrity validation evidence shall be retained.

AUD-SEC-024

Backup security controls shall be verifiable.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Confidentiality
- ISO 27001 Cryptography Controls
- ISO 27002 Data Protection Controls

15. Architectural Constraints

SA-CON-018

Encryption services shall be centralized.

SA-CON-019

Key management shall remain independent of business services.

SA-CON-020

Data security controls shall preserve audit evidence.

SA-CON-021

Data protection architecture shall support future compliance expansion.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

DATA GOVERNANCE V1

API SPEC V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Data disclosure
- Data corruption
- Key compromise
- Unauthorized exports

Mitigation Controls:

- Encryption
- Key management
- Integrity controls
- DLP monitoring

18. Section Summary

This section establishes the TODP Data Security Architecture, defining classification controls, encryption requirements, integrity protections, data loss prevention controls, backup security requirements, governance obligations, audit requirements, and compliance alignment.

SECURITY ARCHITECTURE V1

Section 7 – Application Security Architecture & Secure Development Framework

Document ID: SEC-SA-007

Document Name: Security Architecture V1

Section ID: SA-07

Section Title: Application Security Architecture & Secure Development Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Application Security Architecture and Secure Development Framework governing TODP application services, APIs, user interfaces, processing services, workflows, and supporting components.

The framework establishes secure development requirements and application security controls that shall be integrated throughout the software development lifecycle.

2. Objectives

- Establish secure software development practices.
- Reduce application security risks.
- Protect business logic and data processing.
- Secure APIs and service interactions.
- Support audit and compliance requirements.
- Improve platform resilience.
- Support enterprise customer expectations.
- Enable secure platform growth.

3. Scope

Applies to:

- Web Applications
- APIs
- Internal Services
- Background Jobs
- Governance Services
- Audit Services
- Replay Services
- Administrative Interfaces

4. Secure Development Principles

SEC-APP-001

Security shall be integrated into development activities.

SEC-APP-002

Security reviews shall occur before production deployment.

SEC-APP-003

Security testing shall be performed throughout development.

SEC-APP-004

Application components shall follow secure coding standards.

SEC-APP-005

Security defects shall be tracked and remediated.

SEC-APP-006

Application security controls shall be auditable.

5. Application Security Domains

Domain SEC-APP-DOM-001

Input Security

Purpose:

Prevent malicious input processing.

Domain SEC-APP-DOM-002

Session Security

Purpose:

Protect authenticated sessions.

Domain SEC-APP-DOM-003

API Security

Purpose:

Protect service interfaces.

Domain SEC-APP-DOM-004

Business Logic Security

Purpose:

Protect decision workflows.

Domain SEC-APP-DOM-005

Administrative Security

Purpose:

Protect administrative operations.

6. Secure Coding Requirements

SEC-CODE-001

Input validation shall be enforced.

SEC-CODE-002

Output encoding shall be applied where applicable.

SEC-CODE-003

Secure error handling shall be implemented.

SEC-CODE-004

Secrets shall not be hardcoded.

SEC-CODE-005

Security libraries shall be approved.

SEC-CODE-006

Code reviews shall include security validation.

7. API Security Requirements

SEC-API-001

APIs shall require authentication.

SEC-API-002

APIs shall enforce authorization.

SEC-API-003

API requests shall be logged.

SEC-API-004

Rate limiting shall be supported.

SEC-API-005

Sensitive API operations shall be monitored.

SEC-API-006

API security events shall be auditable.

8. Security Testing Requirements

SEC-TEST-001

Static security testing shall be performed.

SEC-TEST-002

Dependency security analysis shall be performed.

SEC-TEST-003

Application security reviews shall occur before release.

SEC-TEST-004

Critical vulnerabilities shall be remediated before production deployment.

SEC-TEST-005

Security test evidence shall be retained.

9. Vulnerability Management

SEC-VULN-001

Security vulnerabilities shall be documented.

SEC-VULN-002

Risk ratings shall be assigned.

SEC-VULN-003

Remediation ownership shall be assigned.

SEC-VULN-004

Remediation activities shall be tracked.

SEC-VULN-005

Closure validation shall be performed.

10. Administrative Interface Security

SEC-ADM-001

Administrative interfaces shall require enhanced authentication.

SEC-ADM-002

Administrative activities shall be logged.

SEC-ADM-003

Administrative actions shall be auditable.

SEC-ADM-004

Administrative permissions shall be reviewed periodically.

11. Governance Rules

SEC-GOV-026

Secure coding standards shall be mandatory.

SEC-GOV-027

Security testing shall be required before release.

SEC-GOV-028

Critical vulnerabilities shall be remediated.

SEC-GOV-029

Application security evidence shall be retained.

SEC-GOV-030

Application security controls shall support audit and replay requirements.

12. Metrics

SEC-MET-024

Security Review Completion

Target: 100%

SEC-MET-025

Critical Vulnerability Remediation Compliance

Target: 100%

SEC-MET-026

Secure Code Review Coverage

Target: $\geq 95\%$

SEC-MET-027

API Security Compliance

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-025

Security review evidence shall be auditable.

AUD-SEC-026

Vulnerability records shall be reviewable.

AUD-SEC-027

Release approvals shall be retained.

AUD-SEC-028

Security testing evidence shall be verifiable.

14. Compliance Requirements

Supports:

- SOC 2 Security
- ISO 27001 Secure Development
- ISO 27002 Application Security
- Enterprise Security Assessments

15. Architectural Constraints

SA-CON-022

Application security controls shall be embedded within development processes.

SA-CON-023

Security testing shall support CI/CD integration.

SA-CON-024

Application security architecture shall support modular service boundaries.

SA-CON-025

Application controls shall preserve audit and replay requirements.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

TEST SPEC V1

API SPEC V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Software vulnerabilities
- API abuse
- Business logic manipulation
- Administrative misuse

Mitigation Controls:

- Secure coding
- Security testing
- Vulnerability management
- Administrative monitoring

18. Section Summary

This section establishes the TODP Application Security Architecture and Secure Development Framework, defining secure coding requirements, API protections, vulnerability management processes, security testing controls, governance obligations, audit requirements, and compliance alignment.

SECURITY ARCHITECTURE V1

Section 8 – Infrastructure Security Architecture & Platform Hardening Framework

Document ID: SEC-SA-008

Document Name: Security Architecture V1

Section ID: SA-08

Section Title: Infrastructure Security Architecture & Platform Hardening Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Infrastructure Security Architecture and Platform Hardening Framework governing the computing environments, operating systems, containers, storage services, databases, cloud resources, supporting services, and runtime infrastructure used by TODP.

The framework establishes the controls required to protect infrastructure assets from unauthorized access, misuse, compromise, disruption, or configuration drift while supporting enterprise-grade governance, auditability, traceability, and replayability.

2. Objectives

- Establish secure infrastructure foundations.
- Reduce infrastructure attack surfaces.
- Standardize hardening practices.
- Protect production workloads.
- Improve operational resilience.
- Support governance and audit requirements.
- Support enterprise security expectations.
- Enable secure platform scalability.

3. Scope

Applies to:

- Application Servers
- Container Hosts
- Container Runtimes
- Databases
- Search Infrastructure
- Storage Services
- Message Queues
- Monitoring Infrastructure
- Backup Infrastructure
- Disaster Recovery Infrastructure
- CI/CD Infrastructure
- Cloud Resources

4. Infrastructure Security Principles

SEC-INF-001

Infrastructure shall be hardened before production use.

SEC-INF-002

Infrastructure configurations shall be controlled.

SEC-INF-003

Infrastructure changes shall be auditable.

SEC-INF-004

Infrastructure access shall follow least privilege.

SEC-INF-005

Infrastructure monitoring shall be continuous.

SEC-INF-006

Infrastructure controls shall support governance requirements.

5. Infrastructure Security Domains

Domain SEC-INF-DOM-001

Compute Security

Purpose:

Protect compute resources.

Domain SEC-INF-DOM-002

Container Security

Purpose:

Protect containerized workloads.

Domain SEC-INF-DOM-003

Database Security

Purpose:

Protect structured data stores.

Domain SEC-INF-DOM-004

Storage Security

Purpose:

Protect storage resources.

Domain SEC-INF-DOM-005

Cloud Resource Security

Purpose:

Protect cloud-managed services.

6. Platform Hardening Requirements

SEC-HARD-001

Default configurations shall not be used in production.

SEC-HARD-002

Unnecessary services shall be disabled.

SEC-HARD-003

Administrative access shall be restricted.

SEC-HARD-004

Infrastructure baselines shall be documented.

SEC-HARD-005

Hardening standards shall be maintained.

SEC-HARD-006

Hardening reviews shall be performed periodically.

7. Configuration Security Management

SEC-CONF-001

Configuration standards shall be defined.

SEC-CONF-002

Configuration changes shall be approved.

SEC-CONF-003

Configuration drift shall be monitored.

SEC-CONF-004

Configuration repositories shall be controlled.

SEC-CONF-005

Configuration history shall be retained.

8. Container Security Requirements

SEC-CONT-001

Container images shall originate from approved sources.

SEC-CONT-002

Container images shall undergo security review.

SEC-CONT-003

Runtime privileges shall be restricted.

SEC-CONT-004

Container activity shall be monitored.

SEC-CONT-005

Container inventories shall be maintained.

9. Database Security Requirements

SEC-DB-001

Database access shall be restricted.

SEC-DB-002

Database authentication shall be enforced.

SEC-DB-003

Sensitive data shall be protected.

SEC-DB-004

Database activity shall be monitored.

SEC-DB-005

Database audit records shall be retained.

10. Infrastructure Monitoring Requirements

SEC-INF-MON-001

Infrastructure events shall be monitored.

SEC-INF-MON-002

Administrative actions shall be logged.

SEC-INF-MON-003

Infrastructure anomalies shall be investigated.

SEC-INF-MON-004

Monitoring evidence shall be retained.

SEC-INF-MON-005

Monitoring shall support audit reviews.

11. Governance Rules

SEC-GOV-031

Infrastructure hardening shall be mandatory.

SEC-GOV-032

Infrastructure standards shall be documented.

SEC-GOV-033

Configuration changes shall be controlled.

SEC-GOV-034

Infrastructure monitoring shall remain active.

SEC-GOV-035

Infrastructure controls shall support replay and audit requirements.

12. Metrics

SEC-MET-028

Infrastructure Hardening Compliance

Target: $\geq 95\%$

SEC-MET-029

Configuration Review Compliance

Target: $\geq 95\%$

SEC-MET-030

Infrastructure Monitoring Coverage

Target: $\geq 99\%$

SEC-MET-031

Container Security Compliance

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-029

Infrastructure standards shall be auditable.

AUD-SEC-030

Configuration changes shall be reviewable.

AUD-SEC-031

Infrastructure monitoring evidence shall be retained.

AUD-SEC-032

Hardening validation records shall be verifiable.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Availability
- ISO 27001 Operations Security
- ISO 27002 Infrastructure Security

15. Architectural Constraints

SA-CON-026

Infrastructure services shall support service isolation.

SA-CON-027

Infrastructure controls shall support immutable audit records.

SA-CON-028

Infrastructure architecture shall support future scaling requirements.

SA-CON-029

Infrastructure controls shall preserve replay integrity.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Infrastructure compromise
- Configuration drift
- Privilege abuse
- Service disruption

Mitigation Controls:

- Hardening standards
- Monitoring controls

- Configuration management
- Access governance

18. Section Summary

This section establishes the TODP Infrastructure Security Architecture and Platform Hardening Framework, defining infrastructure protection controls, hardening standards, configuration governance, monitoring requirements, audit obligations, compliance alignment, and operational security requirements.

SECURITY ARCHITECTURE V1

Section 9 – Network Security Architecture & Secure Communications Framework

Document ID: SEC-SA-009

Document Name: Security Architecture V1

Section ID: SA-09

Section Title: Network Security Architecture & Secure Communications Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Network Security Architecture and Secure Communications Framework governing communication pathways, service interactions, network boundaries, external connectivity, API communications, administrative communications, and data transmission mechanisms within TODP.

The framework establishes controls necessary to secure communications, restrict unauthorized network access, and maintain trusted connectivity between platform components.

2. Objectives

- Secure platform communications.
- Protect network boundaries.
- Reduce exposure to network-based threats.
- Support secure service interactions.
- Protect administrative communications.
- Support monitoring and incident response.
- Support enterprise customer requirements.
- Maintain secure platform operations.

3. Scope

Applies to:

- Internal Service Traffic
- External API Traffic
- Administrative Traffic
- Database Communications
- Monitoring Traffic
- Backup Traffic
- Integration Traffic
- Audit Communications
- Replay Communications

4. Network Security Principles

SEC-NET-001

Network access shall be restricted.

SEC-NET-002

Network trust shall not be assumed.

SEC-NET-003

Communications shall be protected.

SEC-NET-004

Network activity shall be monitored.

SEC-NET-005

Network segmentation shall be enforced.

SEC-NET-006

Network controls shall support auditability.

5. Network Architecture Domains

Domain SEC-NET-DOM-001

External Access Zone

Purpose:

Manage external communications.

Domain SEC-NET-DOM-002

Application Zone

Purpose:

Host application services.

Domain SEC-NET-DOM-003

Data Zone

Purpose:

Protect data repositories.

Domain SEC-NET-DOM-004

Administrative Zone

Purpose:

Protect administrative functions.

Domain SEC-NET-DOM-005

Monitoring Zone

Purpose:

Protect security monitoring services.

6. Network Segmentation Requirements

SEC-SEG-001

Critical systems shall be logically separated.

SEC-SEG-002

Administrative traffic shall be isolated.

SEC-SEG-003

Data services shall be protected from unnecessary exposure.

SEC-SEG-004

Service communications shall be restricted.

SEC-SEG-005

Segmentation controls shall be periodically reviewed.

7. Secure Communication Requirements

SEC-COMM-001

Sensitive communications shall be encrypted.

SEC-COMM-002

Service-to-service communications shall be authenticated.

SEC-COMM-003

Communication endpoints shall be validated.

SEC-COMM-004

Administrative communications shall receive enhanced protection.

SEC-COMM-005

Communication events shall support auditing.

8. Network Access Control Requirements

SEC-NAC-001

Network access shall require authorization.

SEC-NAC-002

Administrative network access shall be restricted.

SEC-NAC-003

External connectivity shall be controlled.

SEC-NAC-004

Access exceptions shall be approved.

SEC-NAC-005

Access activities shall be logged.

9. Network Monitoring Requirements

SEC-NMON-001

Network traffic shall be monitored.

SEC-NMON-002

Suspicious activity shall be investigated.

SEC-NMON-003

Network security events shall be logged.

SEC-NMON-004

Monitoring evidence shall be retained.

SEC-NMON-005

Network monitoring shall support incident response.

10. Perimeter Security Requirements

SEC-PER-001

External interfaces shall be protected.

SEC-PER-002

Ingress controls shall be enforced.

SEC-PER-003

Exposure reviews shall be performed periodically.

SEC-PER-004

Perimeter security events shall be monitored.

11. Governance Rules

SEC-GOV-036

Network segmentation shall be maintained.

SEC-GOV-037

Network communications shall be protected.

SEC-GOV-038

Network monitoring shall remain active.

SEC-GOV-039

Network access exceptions shall be documented.

SEC-GOV-040

Network controls shall support audit and replay requirements.

12. Metrics

SEC-MET-032

Network Monitoring Coverage

Target: $\geq 99\%$

SEC-MET-033

Secure Communication Compliance

Target: 100%

SEC-MET-034

Segmentation Review Completion

Target: $\geq 95\%$

SEC-MET-035

Network Access Review Compliance

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-033

Network architecture documentation shall be auditable.

AUD-SEC-034

Network access reviews shall be retained.

AUD-SEC-035

Monitoring evidence shall be reviewable.

AUD-SEC-036

Communication protection controls shall be verifiable.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Availability
- ISO 27001 Network Security
- ISO 27002 Communications Security

15. Architectural Constraints

SA-CON-030

Network architecture shall support logical isolation.

SA-CON-031

Network monitoring shall support centralized security operations.

SA-CON-032

Communications security controls shall support audit evidence generation.

SA-CON-033

Network security architecture shall support future enterprise expansion.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

API SPEC V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Network intrusion
- Unauthorized communications

- Traffic interception
- Network misconfiguration

Mitigation Controls:

- Segmentation
- Encryption
- Monitoring
- Access controls

18. Section Summary

This section establishes the TODP Network Security Architecture and Secure Communications Framework, defining network segmentation controls, secure communication requirements, monitoring obligations, perimeter protections, governance requirements, audit obligations, compliance alignment, and architectural constraints.

SECURITY ARCHITECTURE V1

Section 10 – Security Monitoring, Detection & Security Operations Architecture

Document ID: SEC-SA-010

Document Name: Security Architecture V1

Section ID: SA-10

Section Title: Security Monitoring, Detection & Security Operations Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Security Monitoring, Detection, and Security Operations Architecture for TODP.

The architecture establishes the monitoring strategy, detection framework, event collection model, alerting architecture, operational security processes, investigation requirements, governance controls, and audit obligations required to identify, analyze, investigate, and respond to security-relevant events across the TODP platform.

The framework supports proactive threat detection, governance oversight, audit readiness, replayability, and enterprise-grade operational security.

2. Objectives

- Establish centralized security monitoring.
- Detect unauthorized or suspicious activity.
- Support rapid security investigations.
- Enable security event correlation.
- Support governance and compliance requirements.
- Improve operational visibility.
- Support incident response activities.
- Maintain enterprise-grade security operations.

3. Scope

Applies to:

- User Activities
- Administrative Activities
- Authentication Events
- Authorization Events
- Application Events
- Infrastructure Events
- Network Events
- Database Events
- Governance Events
- Audit Events
- Replay Events
- Integration Events

4. Security Monitoring Principles

SEC-MON-001

Security monitoring shall be continuous.

SEC-MON-002

Security-relevant events shall be collected centrally.

SEC-MON-003

Security alerts shall be prioritized based on risk.

SEC-MON-004

Monitoring shall support investigations.

SEC-MON-005

Monitoring shall support auditability.

SEC-MON-006

Monitoring shall preserve replay traceability.

5. Security Operations Architecture

Layer 1

Event Collection

Purpose:

Capture security-relevant activity.

Layer 2

Event Aggregation

Purpose:

Centralize monitoring visibility.

Layer 3

Detection Engine

Purpose:

Identify suspicious behavior.

Layer 4

Alert Management

Purpose:

Prioritize operational response.

Layer 5

Investigation Layer

Purpose:

Support incident analysis.

Layer 6

Governance Layer

Purpose:

Provide oversight and reporting.

6. Security Event Categories

Category SEC-EVT-001

Authentication Events

Examples:

- Login success
- Login failure
- MFA events

Category SEC-EVT-002

Authorization Events

Examples:

- Privilege changes

- Access denials

Category SEC-EVT-003

Administrative Events

Examples:

- Configuration changes
- System administration actions

Category SEC-EVT-004

Application Events

Examples:

- API activity
- Service failures

Category SEC-EVT-005

Infrastructure Events

Examples:

- Host events

- Container events

Category SEC-EVT-006

Governance Events

Examples:

- Governance approvals
- Security exceptions

7. Detection Requirements

SEC-DET-001

Unauthorized access attempts shall be detected.

SEC-DET-002

Privilege escalation attempts shall be detected.

SEC-DET-003

Suspicious administrative activity shall be detected.

SEC-DET-004

Security policy violations shall be detected.

SEC-DET-005

Critical system anomalies shall be detected.

SEC-DET-006

Detection rules shall undergo periodic review.

8. Alert Management Requirements

SEC-ALERT-001

Security alerts shall be classified.

SEC-ALERT-002

Critical alerts shall be escalated.

SEC-ALERT-003

Alert ownership shall be assigned.

SEC-ALERT-004

Alert investigation activities shall be documented.

SEC-ALERT-005

Alert evidence shall be retained.

9. Security Investigation Requirements

SEC-INV-001

Security investigations shall be documented.

SEC-INV-002

Evidence shall be preserved.

SEC-INV-003

Root cause analysis shall be performed.

SEC-INV-004

Investigation outcomes shall be recorded.

SEC-INV-005

Investigation records shall support audits.

10. Security Operations Reporting

Report Type:

Operational Security Report

Frequency:

Weekly

Report Type:

Security Risk Report

Frequency:

Monthly

Report Type:

Executive Security Report

Frequency:

Quarterly

Report Type:

Incident Trend Report

Frequency:

Monthly

11. Governance Rules

SEC-GOV-041

Security monitoring shall remain active.

SEC-GOV-042

Detection rules shall be maintained.

SEC-GOV-043

Critical alerts shall be investigated.

SEC-GOV-044

Monitoring evidence shall be retained.

SEC-GOV-045

Security monitoring shall support audit and replay requirements.

12. Metrics

SEC-MET-036

Monitoring Coverage

Target: $\geq 99\%$

SEC-MET-037

Critical Alert Investigation Compliance

Target: $\geq 95\%$

SEC-MET-038

Detection Rule Review Completion

Target: $\geq 95\%$

SEC-MET-039

Security Event Collection Coverage

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-037

Monitoring configurations shall be auditable.

AUD-SEC-038

Alert investigations shall be reviewable.

AUD-SEC-039

Detection rule changes shall be retained.

AUD-SEC-040

Security monitoring evidence shall support independent verification.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Monitoring Controls
- ISO 27001 Security Monitoring
- ISO 27002 Security Event Management

15. Architectural Constraints

SA-CON-034

Monitoring services shall be centralized.

SA-CON-035

Monitoring repositories shall support historical retention.

SA-CON-036

Monitoring controls shall preserve audit integrity.

SA-CON-037

Monitoring architecture shall support future scaling requirements.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Undetected threats
- Delayed investigations
- Alert fatigue
- Monitoring gaps

Mitigation Controls:

- Centralized monitoring
- Detection engineering

- Investigation procedures
- Governance oversight

18. Section Summary

This section establishes the TODP Security Monitoring, Detection, and Security Operations Architecture, defining monitoring controls, event collection requirements, detection mechanisms, alert management procedures, investigation requirements, governance obligations, audit requirements, and compliance alignment.

SECURITY ARCHITECTURE V1

Section 11 – Security Logging, Audit Trail & Evidence Protection Architecture

Document ID: SEC-SA-011

Document Name: Security Architecture V1

Section ID: SA-11

Section Title: Security Logging, Audit Trail & Evidence Protection Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Security Logging, Audit Trail, and Evidence Protection Architecture governing the collection, storage, protection, retention, traceability, integrity, and auditability of security-related records across TODP.

The framework ensures that security activities can be reconstructed, verified, investigated, audited, and replayed while preserving the integrity of evidence.

2. Objectives

- Establish comprehensive security logging.
- Preserve audit trail integrity.
- Support incident investigations.
- Enable audit readiness.
- Support replay capabilities.
- Improve traceability.
- Protect evidence from unauthorized modification.
- Support compliance requirements.

3. Scope

Applies to:

- Authentication Logs
- Authorization Logs
- Administrative Logs
- Application Logs
- API Logs
- Database Logs
- Infrastructure Logs
- Governance Logs
- Audit Logs

- Replay Logs
- Security Monitoring Logs

4. Logging Principles

SEC-LOG-001

Security-relevant events shall be logged.

SEC-LOG-002

Logs shall support traceability.

SEC-LOG-003

Logs shall be protected from unauthorized modification.

SEC-LOG-004

Logs shall support investigations.

SEC-LOG-005

Logs shall support audit requirements.

SEC-LOG-006

Logs shall preserve replay capability.

5. Audit Trail Architecture

Layer 1

Event Generation

Purpose:

Generate security records.

Layer 2

Log Collection

Purpose:

Aggregate security events.

Layer 3

Evidence Repository

Purpose:

Preserve evidence integrity.

Layer 4

Audit Access Layer

Purpose:

Support authorized review.

Layer 5

Governance Layer

Purpose:

Oversight and compliance.

6. Mandatory Logging Requirements

SEC-LOG-REQ-001

Authentication events shall be logged.

SEC-LOG-REQ-002

Authorization events shall be logged.

SEC-LOG-REQ-003

Administrative activities shall be logged.

SEC-LOG-REQ-004

Configuration changes shall be logged.

SEC-LOG-REQ-005

Security incidents shall be logged.

SEC-LOG-REQ-006

Governance approvals shall be logged.

7. Evidence Protection Requirements

SEC-EVID-001

Evidence repositories shall be protected.

SEC-EVID-002

Evidence access shall be controlled.

SEC-EVID-003

Evidence integrity shall be validated.

SEC-EVID-004

Evidence retention requirements shall be enforced.

SEC-EVID-005

Evidence deletion shall be governed.

8. Log Integrity Requirements

SEC-INTG-006

Audit records shall be immutable.

SEC-INTG-007

Log tampering shall be detectable.

SEC-INTG-008

Integrity validation shall be performed.

SEC-INTG-009

Integrity violations shall be investigated.

9. Retention Requirements

Authentication Logs:

Minimum Retention: 5 Years

Authorization Logs:

Minimum Retention: 5 Years

Administrative Logs:

Minimum Retention: 7 Years

Security Incident Records:

Minimum Retention: 10 Years

Audit Evidence:

Minimum Retention: 10 Years

Replay Security Records:

Minimum Retention: 10 Years

10. Evidence Access Requirements

SEC-EA-001

Evidence access shall require authorization.

SEC-EA-002

Evidence reviews shall be logged.

SEC-EA-003

Evidence exports shall be controlled.

SEC-EA-004

Evidence sharing shall be approved.

11. Governance Rules

SEC-GOV-046

Mandatory logging controls shall be enforced.

SEC-GOV-047

Audit trails shall remain protected.

SEC-GOV-048

Evidence repositories shall be governed.

SEC-GOV-049

Integrity validation shall be performed.

SEC-GOV-050

Audit trails shall support replay and audit requirements.

12. Metrics

SEC-MET-040

Security Logging Coverage

Target: $\geq 99\%$

SEC-MET-041

Evidence Integrity Validation Success Rate

Target: $\geq 99\%$

SEC-MET-042

Mandatory Logging Compliance

Target: 100%

SEC-MET-043

Evidence Access Review Compliance

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-041

Audit trail coverage shall be verifiable.

AUD-SEC-042

Evidence repositories shall be auditable.

AUD-SEC-043

Integrity validation activities shall be reviewable.

AUD-SEC-044

Retention compliance shall be independently verified.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Processing Integrity
- ISO 27001 Logging Controls
- ISO 27002 Audit Logging Controls

15. Architectural Constraints

SA-CON-038

Audit repositories shall be logically separated from operational repositories.

SA-CON-039

Evidence storage shall support immutability.

SA-CON-040

Logging architecture shall support high-volume event processing.

SA-CON-041

Logging controls shall preserve replay reconstruction capabilities.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

AUDIT MODULE DOCUMENTATION

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Log tampering
- Missing evidence
- Audit deficiencies
- Investigation failures

Mitigation Controls:

- Immutable storage
- Integrity validation
- Controlled access
- Retention governance

18. Section Summary

This section establishes the TODP Security Logging, Audit Trail, and Evidence Protection Architecture, defining logging requirements, evidence protection controls, retention requirements, integrity validation mechanisms, governance obligations, audit requirements, and compliance alignment.

SECURITY ARCHITECTURE V1

Section 12 – Security Incident Response & Cyber Resilience Architecture

Document ID: SEC-SA-012

Document Name: Security Architecture V1

Section ID: SA-12

Section Title: Security Incident Response & Cyber Resilience Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Security Incident Response and Cyber Resilience Architecture for TODP.

The architecture establishes the governance framework, operational processes, response procedures, escalation mechanisms, resilience controls, investigation requirements, communication requirements, and recovery activities required to manage security incidents affecting TODP.

The objective is to ensure that security incidents are rapidly detected, contained, investigated, remediated, documented, and learned from while preserving platform integrity, auditability, governance obligations, and replay capabilities.

2. Objectives

- Establish a formal incident response capability.
- Minimize business impact from security incidents.
- Support rapid containment and recovery.
- Preserve forensic evidence.
- Support audit and compliance requirements.
- Improve operational resilience.
- Enable lessons learned activities.
- Support enterprise customer security expectations.

3. Scope

Applies to:

- Security Incidents
- Data Breaches
- Unauthorized Access Events
- Malware Events
- Insider Threat Events
- Infrastructure Compromises
- Application Security Incidents
- Third-Party Security Incidents
- Governance Security Incidents
- Audit Integrity Events

4. Security Incident Management Principles

SEC-IR-001

All security incidents shall be documented.

SEC-IR-002

Incident severity shall be assessed.

SEC-IR-003

Evidence shall be preserved.

SEC-IR-004

Incident ownership shall be assigned.

SEC-IR-005

Material incidents shall be escalated.

SEC-IR-006

Lessons learned shall be performed.

5. Incident Response Lifecycle

Phase 1

Preparation

Purpose:

Establish readiness.

Phase 2

Detection

Purpose:

Identify security incidents.

Phase 3

Analysis

Purpose:

Determine scope and severity.

Phase 4

Containment

Purpose:

Limit impact.

Phase 5

Eradication

Purpose:

Remove threats.

Phase 6

Recovery

Purpose:

Restore operations.

Phase 7

Lessons Learned

Purpose:

Improve future response capability.

6. Incident Severity Classification

Severity Level 1

Low

Examples:

- Minor policy violations

- Isolated operational events

Severity Level 2

Medium

Examples:

- Limited security control failures
- Localized compromise attempts

Severity Level 3

High

Examples:

- Confirmed unauthorized access
- Material operational impact

Severity Level 4

Critical

Examples:

- Major data compromise

- Significant business disruption
- Regulatory reporting implications

7. Incident Detection Requirements

SEC-IR-DET-001

Security monitoring systems shall support incident detection.

SEC-IR-DET-002

Critical alerts shall be investigated.

SEC-IR-DET-003

Anomalous activity shall be reviewed.

SEC-IR-DET-004

Detection evidence shall be retained.

SEC-IR-DET-005

Detection processes shall support audits.

8. Incident Escalation Requirements

SEC-IR-ESC-001

High severity incidents shall be escalated immediately.

SEC-IR-ESC-002

Critical incidents shall be reported to executive leadership.

SEC-IR-ESC-003

Material incidents shall trigger governance review.

SEC-IR-ESC-004

Escalation decisions shall be documented.

SEC-IR-ESC-005

Escalation records shall be retained.

9. Forensic Evidence Requirements

SEC-FOR-001

Evidence shall be collected using approved procedures.

SEC-FOR-002

Chain-of-custody records shall be maintained.

SEC-FOR-003

Evidence integrity shall be validated.

SEC-FOR-004

Evidence repositories shall be protected.

SEC-FOR-005

Evidence shall support independent review.

10. Cyber Resilience Requirements

SEC-RES-001

Critical services shall support recovery procedures.

SEC-RES-002

Recovery plans shall be documented.

SEC-RES-003

Recovery exercises shall be performed.

SEC-RES-004

Resilience testing shall be conducted periodically.

SEC-RES-005

Recovery evidence shall be retained.

11. Post-Incident Review Requirements

SEC-PIR-001

Root cause analysis shall be completed.

SEC-PIR-002

Corrective actions shall be documented.

SEC-PIR-003

Control deficiencies shall be identified.

SEC-PIR-004

Lessons learned shall be retained.

SEC-PIR-005

Review outcomes shall be reported.

12. Governance Rules

SEC-GOV-051

Security incidents shall be documented.

SEC-GOV-052

Incident severity classifications shall be applied consistently.

SEC-GOV-053

Evidence preservation shall be mandatory.

SEC-GOV-054

Critical incidents shall undergo executive review.

SEC-GOV-055

Incident response activities shall support audit and replay requirements.

13. Metrics

SEC-MET-044

Incident Documentation Compliance

Target: 100%

SEC-MET-045

Critical Incident Escalation Compliance

Target: 100%

SEC-MET-046

Post-Incident Review Completion

Target: $\geq 95\%$

SEC-MET-047

Recovery Exercise Completion

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-045

Incident records shall be auditable.

AUD-SEC-046

Forensic evidence shall be reviewable.

AUD-SEC-047

Incident escalations shall be verifiable.

AUD-SEC-048

Corrective action tracking shall support independent validation.

15. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Availability
- ISO 27001 Incident Management
- ISO 27002 Information Security Incident Management

16. Architectural Constraints

SA-CON-042

Incident repositories shall preserve evidence integrity.

SA-CON-043

Incident management systems shall support traceability.

SA-CON-044

Response processes shall preserve audit evidence.

SA-CON-045

Resilience architecture shall support replay reconstruction.

17. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

OPS RUNBOOK V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Delayed response
- Evidence loss
- Inadequate recovery
- Escalation failures

Mitigation Controls:

- Response procedures
- Forensic controls
- Recovery testing

- Executive oversight

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Operations Team

Governance Office

Audit Office

20. Section Summary

This section establishes the TODP Security Incident Response and Cyber Resilience Architecture, defining incident response lifecycle processes, forensic controls, escalation requirements, resilience mechanisms, governance obligations, audit requirements, and compliance alignment.

SECURITY ARCHITECTURE V1

Section 13 – Vulnerability Management, Threat Management & Security Risk Architecture

Document ID: SEC-SA-013

Document Name: Security Architecture V1

Section ID: SA-13

Section Title: Vulnerability Management, Threat Management & Security Risk Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Vulnerability Management, Threat Management, and Security Risk Architecture governing identification, assessment, prioritization, remediation, monitoring, and reporting of security weaknesses and threats affecting TODP.

The framework provides the operational and governance mechanisms necessary to maintain an acceptable security risk posture while supporting enterprise readiness and regulatory expectations.

2. Objectives

- Establish formal vulnerability management processes.
- Identify and manage security threats.
- Reduce platform risk exposure.
- Improve remediation effectiveness.
- Support security governance.
- Support compliance requirements.
- Enable risk-based decision making.
- Improve security posture visibility.

3. Scope

Applies to:

- Applications
- APIs
- Infrastructure
- Databases
- Containers
- Cloud Services
- Third-Party Components
- Open Source Dependencies
- Administrative Interfaces
- Monitoring Systems

4. Security Risk Principles

SEC-RISK-001

Security risks shall be documented.

SEC-RISK-002

Risk ownership shall be assigned.

SEC-RISK-003

Risk treatment plans shall be maintained.

SEC-RISK-004

Risk acceptance shall be formally approved.

SEC-RISK-005

Security risks shall be periodically reviewed.

SEC-RISK-006

Risk management activities shall support auditability.

5. Vulnerability Management Lifecycle

Phase 1

Identification

Purpose:

Discover vulnerabilities.

Phase 2

Assessment

Purpose:

Determine risk.

Phase 3

Prioritization

Purpose:

Rank remediation activities.

Phase 4

Remediation

Purpose:

Reduce exposure.

Phase 5

Validation

Purpose:

Confirm remediation effectiveness.

Phase 6

Closure

Purpose:

Complete lifecycle management.

6. Vulnerability Severity Framework

Severity

Low

Characteristics:

Limited security impact.

Severity

Medium

Characteristics:

Moderate security exposure.

Severity

High

Characteristics:

Material security weakness.

Severity

Critical

Characteristics:

Immediate security threat requiring urgent remediation.

7. Vulnerability Identification Requirements

SEC-VULN-ID-001

Security assessments shall be performed periodically.

SEC-VULN-ID-002

Application vulnerabilities shall be tracked.

SEC-VULN-ID-003

Infrastructure vulnerabilities shall be tracked.

SEC-VULN-ID-004

Dependency vulnerabilities shall be monitored.

SEC-VULN-ID-005

Assessment evidence shall be retained.

8. Threat Management Requirements

SEC-THREAT-001

Threat intelligence sources shall be evaluated.

SEC-THREAT-002

Relevant threats shall be documented.

SEC-THREAT-003

Threat impacts shall be assessed.

SEC-THREAT-004

Threat monitoring activities shall be performed.

SEC-THREAT-005

Threat records shall be retained.

9. Risk Treatment Requirements

SEC-RISK-TREAT-001

Remediation plans shall be documented.

SEC-RISK-TREAT-002

Owners shall be assigned.

SEC-RISK-TREAT-003

Target completion dates shall be defined.

SEC-RISK-TREAT-004

Progress shall be monitored.

SEC-RISK-TREAT-005

Closure validation shall be performed.

10. Security Risk Acceptance Requirements

SEC-RISK-ACC-001

Risk acceptance shall be documented.

SEC-RISK-ACC-002

Business justification shall be recorded.

SEC-RISK-ACC-003

Compensating controls shall be identified.

SEC-RISK-ACC-004

Acceptance approvals shall be retained.

SEC-RISK-ACC-005

Accepted risks shall be reviewed periodically.

11. Security Risk Register Requirements

SEC-RR-001

Material security risks shall be recorded.

SEC-RR-002

Risk owners shall be assigned.

SEC-RR-003

Risk ratings shall be maintained.

SEC-RR-004

Treatment status shall be tracked.

SEC-RR-005

Historical records shall be retained.

12. Governance Rules

SEC-GOV-056

Security vulnerabilities shall be documented.

SEC-GOV-057

Critical vulnerabilities shall be prioritized.

SEC-GOV-058

Threat assessments shall be maintained.

SEC-GOV-059

Security risks shall be reviewed periodically.

SEC-GOV-060

Risk management activities shall support audit and replay requirements.

13. Metrics

SEC-MET-048

Vulnerability Assessment Coverage

Target: $\geq 95\%$

SEC-MET-049

Critical Vulnerability Remediation Compliance

Target: 100%

SEC-MET-050

Risk Register Coverage

Target: 100%

SEC-MET-051

Threat Review Completion

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-049

Vulnerability records shall be auditable.

AUD-SEC-050

Risk acceptance decisions shall be reviewable.

AUD-SEC-051

Threat assessments shall be retained.

AUD-SEC-052

Risk treatment plans shall support independent verification.

15. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Risk Assessment
- ISO 27001 Risk Management
- ISO 27002 Vulnerability Management

16. Architectural Constraints

SA-CON-046

Risk repositories shall support historical retention.

SA-CON-047

Threat management systems shall support traceability.

SA-CON-048

Risk management controls shall preserve audit evidence.

SA-CON-049

Security risk architecture shall support future compliance expansion.

17. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

ENTERPRISE RISK REGISTER

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Unpatched vulnerabilities
- Emerging threats
- Excessive risk exposure
- Delayed remediation

Mitigation Controls:

- Vulnerability management
- Threat monitoring
- Risk governance
- Periodic reviews

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Engineering Teams

Operations Teams

Governance Office

20. Section Summary

This section establishes the TODP Vulnerability Management, Threat Management, and Security Risk Architecture, defining vulnerability lifecycle processes, threat management requirements, risk treatment procedures, governance obligations, audit requirements, compliance alignment, and enterprise security risk controls.

SECURITY ARCHITECTURE V1

Section 14 – Security Compliance Architecture, Regulatory Alignment & Assurance Framework

Document ID: SEC-SA-014

Document Name: Security Architecture V1

Section ID: SA-14

Section Title: Security Compliance Architecture, Regulatory Alignment & Assurance Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Security Compliance Architecture, Regulatory Alignment, and Assurance Framework governing how TODP security controls are mapped, validated, monitored, assessed, and maintained against enterprise security obligations, regulatory expectations, customer security requirements, and industry-recognized frameworks.

The framework ensures that security controls remain measurable, auditable, traceable, and continuously aligned with evolving compliance requirements.

2. Objectives

- Establish security compliance governance.

- Maintain regulatory alignment.
- Support enterprise customer assessments.
- Support audit readiness.
- Demonstrate security control effectiveness.
- Improve compliance visibility.
- Support future certification programs.
- Maintain security assurance maturity.

3. Scope

Applies to:

- Security Policies
- Security Standards
- Security Procedures
- Security Controls
- Security Monitoring
- Security Evidence Repositories
- Audit Records
- Governance Records
- Risk Registers
- Compliance Reports

4. Compliance Architecture Principles

SEC-COMP-001

Compliance activities shall be evidence-based.

SEC-COMP-002

Security controls shall map to compliance obligations.

SEC-COMP-003

Compliance evidence shall be traceable.

SEC-COMP-004

Compliance assessments shall be repeatable.

SEC-COMP-005

Compliance records shall be auditable.

SEC-COMP-006

Compliance governance shall support continuous improvement.

5. Compliance Alignment Domains

Domain SEC-COMP-DOM-001

SOC 2 Readiness

Coverage:

- Security
- Availability
- Confidentiality
- Processing Integrity

Domain SEC-COMP-DOM-002

ISO 27001 Readiness

Coverage:

- Governance
- Risk Management
- Access Control
- Operations Security

Domain SEC-COMP-DOM-003

ISO 27002 Alignment

Coverage:

- Security Controls
- Security Operations

- Monitoring Controls

Domain SEC-COMP-DOM-004

Enterprise Procurement Readiness

Coverage:

- Security Governance
- Security Operations
- Risk Management

Domain SEC-COMP-DOM-005

Customer Security Reviews

Coverage:

- Security Architecture
- Auditability
- Security Evidence

6. Security Control Mapping Requirements

SEC-MAP-001

Security controls shall be mapped to applicable obligations.

SEC-MAP-002

Control ownership shall be documented.

SEC-MAP-003

Control effectiveness shall be measurable.

SEC-MAP-004

Control gaps shall be documented.

SEC-MAP-005

Mapping records shall be maintained.

7. Assurance Framework

Assurance Layer 1

Control Self-Assessment

Purpose:

Validate operational effectiveness.

Assurance Layer 2

Security Governance Review

Purpose:

Validate compliance alignment.

Assurance Layer 3

Internal Security Assessment

Purpose:

Independent verification.

Assurance Layer 4

External Review

Purpose:

Customer or third-party assessment.

Assurance Layer 5

Executive Oversight

Purpose:

Enterprise security accountability.

8. Security Assessment Requirements

SEC-ASMT-001

Security assessments shall be planned.

SEC-ASMT-002

Assessment scope shall be documented.

SEC-ASMT-003

Evidence shall be collected.

SEC-ASMT-004

Findings shall be classified.

SEC-ASMT-005

Corrective actions shall be tracked.

9. Compliance Evidence Requirements

SEC-EVID-COMP-001

Evidence sources shall be identified.

SEC-EVID-COMP-002

Evidence integrity shall be protected.

SEC-EVID-COMP-003

Evidence retention requirements shall be enforced.

SEC-EVID-COMP-004

Evidence repositories shall be governed.

SEC-EVID-COMP-005

Evidence shall support independent review.

10. Security Findings Management

SEC-FIND-001

Findings shall be documented.

SEC-FIND-002

Severity ratings shall be assigned.

SEC-FIND-003

Owners shall be assigned.

SEC-FIND-004

Remediation plans shall be tracked.

SEC-FIND-005

Closure validation shall be completed.

11. Governance Rules

SEC-GOV-061

Compliance mappings shall be maintained.

SEC-GOV-062

Security assessments shall be performed.

SEC-GOV-063

Security evidence shall be retained.

SEC-GOV-064

Material findings shall be escalated.

SEC-GOV-065

Compliance activities shall support audit and replay requirements.

12. Metrics

SEC-MET-052

Control Mapping Coverage

Target: 100%

SEC-MET-053

Assessment Completion Rate

Target: $\geq 95\%$

SEC-MET-054

Finding Closure Compliance

Target: $\geq 90\%$

SEC-MET-055

Evidence Completeness

Target: $\geq 98\%$

13. Audit Requirements

AUD-SEC-053

Compliance mappings shall be auditable.

AUD-SEC-054

Assessment evidence shall be reviewable.

AUD-SEC-055

Finding remediation records shall be retained.

AUD-SEC-056

Security assurance activities shall support independent verification.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Availability
- ISO 27001 Internal Assessment
- ISO 27002 Security Assurance

15. Architectural Constraints

SA-CON-050

Compliance repositories shall support traceability.

SA-CON-051

Evidence repositories shall support immutability.

SA-CON-052

Assurance records shall support historical retention.

SA-CON-053

Compliance architecture shall support future certification programs.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

COMPLIANCE PACKAGE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Compliance gaps
- Assessment failures
- Missing evidence
- Regulatory misalignment

Mitigation Controls:

- Compliance mapping
- Assurance reviews
- Evidence management
- Governance oversight

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Audit Office

Compliance Team

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Regulatory changes
- Major architecture changes
- Enterprise customer requirements

20. Section Summary

This section establishes the TODP Security Compliance Architecture, Regulatory Alignment, and Assurance Framework, defining compliance mappings, assessment activities, evidence requirements, assurance mechanisms, governance obligations, audit requirements, and enterprise security compliance controls.

SECURITY ARCHITECTURE V1

Section 15 – Security Audit Architecture, Control Validation & Independent Verification Framework

Document ID: SEC-SA-015

Document Name: Security Architecture V1

Section ID: SA-15

Section Title: Security Audit Architecture, Control Validation & Independent Verification Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Security Audit Architecture, Control Validation, and Independent Verification Framework governing how security controls are tested, validated, reviewed, measured, and independently assessed across TODP.

The framework provides assurance that security controls operate as intended and continue to support enterprise security objectives, governance obligations, compliance requirements, and audit readiness.

2. Objectives

- Validate security control effectiveness.
- Support independent verification.
- Improve security accountability.
- Detect control weaknesses.
- Support governance oversight.
- Enable audit readiness.
- Strengthen enterprise trust.
- Support continuous security improvement.

3. Scope

Applies to:

- Identity Controls

- Access Controls
- Data Protection Controls
- Infrastructure Controls
- Network Controls
- Monitoring Controls
- Incident Response Controls
- Compliance Controls
- Audit Controls
- Replay Security Controls

4. Audit Principles

SEC-AUD-001

Security controls shall be independently verifiable.

SEC-AUD-002

Audit activities shall be evidence-based.

SEC-AUD-003

Control testing shall be repeatable.

SEC-AUD-004

Audit findings shall be documented.

SEC-AUD-005

Audit activities shall preserve objectivity.

SEC-AUD-006

Audit evidence shall remain traceable.

5. Security Audit Model

Level 1

Operational Validation

Purpose:

Control owner verification.

Level 2

Security Office Review

Purpose:

Control governance validation.

Level 3

Internal Audit Review

Purpose:

Independent assessment.

Level 4

External Assessment

Purpose:

Customer or third-party validation.

Level 5

Executive Oversight

Purpose:

Security accountability.

6. Security Control Testing Categories

Category SEC-TEST-001

Identity Security Testing

Category SEC-TEST-002

Authorization Testing

Category SEC-TEST-003

Data Protection Testing

Category SEC-TEST-004

Infrastructure Security Testing

Category SEC-TEST-005

Monitoring Control Testing

Category SEC-TEST-006

Incident Response Validation

7. Audit Planning Requirements

SEC-AUD-PLAN-001

Audit plans shall be documented.

SEC-AUD-PLAN-002

Audit scope shall be approved.

SEC-AUD-PLAN-003

Control inventories shall be maintained.

SEC-AUD-PLAN-004

Testing procedures shall be documented.

SEC-AUD-PLAN-005

Audit schedules shall be maintained.

8. Security Control Validation Requirements

SEC-VAL-001

Control testing shall be performed.

SEC-VAL-002

Testing evidence shall be retained.

SEC-VAL-003

Control deficiencies shall be documented.

SEC-VAL-004

Control effectiveness shall be evaluated.

SEC-VAL-005

Validation results shall be retained.

9. Audit Finding Classification

Low

Definition:

Minor control weakness.

Medium

Definition:

Moderate security concern.

High

Definition:

Material control deficiency.

Critical

Definition:

Significant security risk requiring executive attention.

10. Remediation Governance

SEC-REM-001

Findings shall receive owners.

SEC-REM-002

Corrective actions shall be documented.

SEC-REM-003

Target dates shall be assigned.

SEC-REM-004

Progress shall be monitored.

SEC-REM-005

Closure validation shall be completed.

11. Independent Verification Requirements

SEC-IV-001

Independent reviews shall occur periodically.

SEC-IV-002

Validation evidence shall be retained.

SEC-IV-003

Review conclusions shall be documented.

SEC-IV-004

Material deficiencies shall be escalated.

SEC-IV-005

Independent assessments shall support audit readiness.

12. Governance Rules

SEC-GOV-066

Security controls shall undergo validation.

SEC-GOV-067

Audit evidence shall be retained.

SEC-GOV-068

Audit findings shall be tracked.

SEC-GOV-069

Material deficiencies shall be escalated.

SEC-GOV-070

Audit activities shall support replay and traceability requirements.

13. Metrics

SEC-MET-056

Control Testing Coverage

Target: $\geq 95\%$

SEC-MET-057

Audit Plan Completion

Target: 100%

SEC-MET-058

Finding Closure Rate

Target: $\geq 90\%$

SEC-MET-059

Independent Review Completion

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-057

Control testing evidence shall be auditable.

AUD-SEC-058

Audit plans shall be reviewable.

AUD-SEC-059

Finding remediation activities shall be verifiable.

AUD-SEC-060

Independent assessments shall support external review.

15. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Monitoring Controls
- ISO 27001 Internal Audit
- ISO 27002 Control Validation

16. Architectural Constraints

SA-CON-054

Audit repositories shall support immutable evidence storage.

SA-CON-055

Audit records shall support long-term retention.

SA-CON-056

Validation activities shall preserve traceability.

SA-CON-057

Security audit architecture shall support future assurance programs.

17. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

TEST SPEC V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Control failures
- Inadequate testing
- Unresolved findings
- Audit deficiencies

Mitigation Controls:

- Independent reviews
- Control validation
- Remediation tracking
- Executive oversight

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Audit Office

Governance Office

Engineering Leadership

20. Section Summary

This section establishes the TODP Security Audit Architecture, Control Validation, and Independent Verification Framework, defining audit processes, control testing requirements, independent review mechanisms, remediation governance, assurance activities, audit obligations, and enterprise security validation controls.

SECURITY ARCHITECTURE V1

Section 16 – Business Continuity, Disaster Recovery & Security Resilience Architecture

Document ID: SEC-SA-016

Document Name: Security Architecture V1

Section ID: SA-16

Section Title: Business Continuity, Disaster Recovery & Security Resilience Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Business Continuity, Disaster Recovery, and Security Resilience Architecture for TODP.

The architecture establishes the governance model, resilience controls, continuity planning requirements, recovery objectives, recovery procedures, testing requirements, audit obligations, and compliance expectations necessary to ensure TODP can continue critical operations or recover within acceptable timeframes following disruptive events.

The framework supports operational continuity while preserving transparency, explainability, traceability, governance, auditability, and replayability.

2. Objectives

- Ensure continuity of critical services.
- Minimize operational disruption.
- Establish recovery capabilities.
- Protect critical data assets.
- Support cyber resilience objectives.
- Support governance and audit requirements.
- Maintain enterprise customer confidence.
- Improve organizational resilience.

3. Scope

Applies to:

- Opportunity Services
- Authority Services
- Evidence Services
- Retrieval Services
- Ranking Services
- Recommendation Services
- Governance Services
- Audit Services
- Replay Services
- Databases
- Search Infrastructure
- Storage Services
- Monitoring Services
- Identity Services

4. Resilience Principles

SEC-RES-006

Critical services shall support continuity planning.

SEC-RES-007

Recovery capabilities shall be tested.

SEC-RES-008

Recovery procedures shall be documented.

SEC-RES-009

Recovery evidence shall be retained.

SEC-RES-010

Resilience controls shall be auditable.

SEC-RES-011

Recovery architecture shall support replay integrity.

5. Business Continuity Framework

Continuity Layer 1

Business Process Continuity

Purpose:

Maintain critical business functions.

Continuity Layer 2

Application Continuity

Purpose:

Maintain platform operations.

Continuity Layer 3

Data Continuity

Purpose:

Protect governed information.

Continuity Layer 4

Infrastructure Continuity

Purpose:

Maintain supporting technology services.

Continuity Layer 5

Governance Continuity

Purpose:

Preserve governance oversight.

6. Recovery Objectives

Recovery Time Objective (RTO)

Definition:

Maximum acceptable service recovery duration.

Recovery Point Objective (RPO)

Definition:

Maximum acceptable data loss duration.

Recovery objectives shall be documented for all critical services.

7. Disaster Recovery Requirements

SEC-DR-001

Disaster recovery plans shall be maintained.

SEC-DR-002

Recovery procedures shall be documented.

SEC-DR-003

Recovery ownership shall be assigned.

SEC-DR-004

Recovery dependencies shall be identified.

SEC-DR-005

Recovery evidence shall be retained.

8. Backup & Recovery Governance

SEC-BCR-001

Critical data shall be backed up.

SEC-BCR-002

Backup integrity shall be validated.

SEC-BCR-003

Recovery testing shall be performed.

SEC-BCR-004

Backup access shall be controlled.

SEC-BCR-005

Backup governance activities shall be auditable.

9. Recovery Testing Requirements

SEC-DR-TEST-001

Recovery exercises shall be conducted periodically.

SEC-DR-TEST-002

Recovery outcomes shall be documented.

SEC-DR-TEST-003

Deficiencies shall be tracked.

SEC-DR-TEST-004

Corrective actions shall be assigned.

SEC-DR-TEST-005

Testing evidence shall be retained.

10. Crisis Management Requirements

SEC-CRISIS-001

Crisis response roles shall be assigned.

SEC-CRISIS-002

Escalation procedures shall be documented.

SEC-CRISIS-003

Stakeholder communications shall be coordinated.

SEC-CRISIS-004

Executive reporting shall be supported.

SEC-CRISIS-005

Crisis activities shall be documented.

11. Governance Rules

SEC-GOV-071

Recovery plans shall remain current.

SEC-GOV-072

Recovery testing shall be mandatory.

SEC-GOV-073

Recovery deficiencies shall be tracked.

SEC-GOV-074

Backup governance shall be enforced.

SEC-GOV-075

Recovery controls shall support audit and replay requirements.

12. Metrics

SEC-MET-060

Recovery Testing Completion

Target: $\geq 95\%$

SEC-MET-061

Backup Validation Success Rate

Target: $\geq 99\%$

SEC-MET-062

Recovery Plan Review Compliance

Target: $\geq 95\%$

SEC-MET-063

Corrective Action Closure Rate

Target: $\geq 90\%$

13. Audit Requirements

AUD-SEC-061

Recovery plans shall be auditable.

AUD-SEC-062

Recovery testing evidence shall be retained.

AUD-SEC-063

Backup validation activities shall be reviewable.

AUD-SEC-064

Recovery governance activities shall support independent verification.

14. Compliance Requirements

Supports:

- SOC 2 Availability
- SOC 2 Security
- ISO 27001 Business Continuity
- ISO 27002 ICT Readiness

15. Architectural Constraints

SA-CON-058

Recovery repositories shall support evidence retention.

SA-CON-059

Recovery controls shall preserve audit integrity.

SA-CON-060

Recovery architecture shall support replay reconstruction.

SA-CON-061

Resilience architecture shall support enterprise growth.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

OPS RUNBOOK V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Service outages
- Data loss
- Recovery failures
- Crisis coordination failures

Mitigation Controls:

- Recovery planning
- Backup governance
- Recovery testing
- Crisis management

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Operations Leadership

Governance Office

Engineering Leadership

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Major outages
- Architecture changes
- Regulatory changes

20. Section Summary

This section establishes the TODP Business Continuity, Disaster Recovery, and Security Resilience Architecture, defining recovery objectives, continuity controls, recovery testing requirements, crisis management processes, governance obligations, audit requirements, and resilience capabilities.

Section 17 – Third-Party Security, Vendor Risk & Supply Chain Security Architecture

Document ID: SEC-SA-017

Document Name: Security Architecture V1

Section ID: SA-17

Section Title: Third-Party Security, Vendor Risk & Supply Chain Security Architecture

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Third-Party Security, Vendor Risk, and Supply Chain Security Architecture governing external organizations, software providers, cloud providers, contractors, consultants, service providers, and technology dependencies used by TODP.

The framework establishes controls necessary to identify, evaluate, monitor, govern, and mitigate risks associated with third-party relationships and software supply chains.

2. Objectives

- Establish third-party security governance.
- Reduce vendor-related risks.
- Improve visibility into external dependencies.
- Protect TODP from supply chain threats.
- Support enterprise procurement requirements.
- Support customer security reviews.
- Maintain compliance readiness.

- Enable secure ecosystem growth.

3. Scope

Applies to:

- Cloud Providers
- SaaS Providers
- Technology Vendors
- Security Vendors
- Open Source Components
- Contractors
- Consultants
- Managed Service Providers
- Data Providers
- Integration Partners

4. Third-Party Security Principles

SEC-TP-001

Third-party risks shall be assessed.

SEC-TP-002

Third-party ownership shall be assigned.

SEC-TP-003

Critical suppliers shall undergo enhanced review.

SEC-TP-004

Third-party security controls shall be monitored.

SEC-TP-005

Supplier relationships shall be auditable.

SEC-TP-006

Supply chain controls shall support governance requirements.

5. Third-Party Risk Categories

Category SEC-TP-CAT-001

Security Risk

Examples:

- Weak security controls
- Unauthorized access exposure

Category SEC-TP-CAT-002

Operational Risk

Examples:

- Service outages
- Support failures

Category SEC-TP-CAT-003

Compliance Risk

Examples:

- Regulatory deficiencies
- Audit deficiencies

Category SEC-TP-CAT-004

Data Risk

Examples:

- Data disclosure
- Data misuse

Category SEC-TP-CAT-005

Supply Chain Risk

Examples:

- Dependency compromise
- Software integrity failures

6. Vendor Security Assessment Requirements

SEC-VSA-001

Security assessments shall be performed before onboarding.

SEC-VSA-002

Critical vendors shall undergo enhanced assessment.

SEC-VSA-003

Assessment evidence shall be retained.

SEC-VSA-004

Assessment outcomes shall be documented.

SEC-VSA-005

Assessment approvals shall be recorded.

7. Vendor Governance Requirements

SEC-VEND-001

Vendor ownership shall be assigned.

SEC-VEND-002

Vendor inventories shall be maintained.

SEC-VEND-003

Vendor reviews shall occur periodically.

SEC-VEND-004

Vendor risk ratings shall be maintained.

SEC-VEND-005

Material vendor changes shall be assessed.

8. Supply Chain Security Requirements

SEC-SC-001

Software dependencies shall be inventoried.

SEC-SC-002

Dependency sources shall be approved.

SEC-SC-003

Dependency vulnerabilities shall be monitored.

SEC-SC-004

Software integrity shall be validated.

SEC-SC-005

Supply chain records shall be retained.

9. Third-Party Monitoring Requirements

SEC-TP-MON-001

Critical vendors shall be monitored.

SEC-TP-MON-002

Vendor incidents shall be evaluated.

SEC-TP-MON-003

Security deficiencies shall be tracked.

SEC-TP-MON-004

Monitoring evidence shall be retained.

SEC-TP-MON-005

Monitoring activities shall support audits.

10. Contractual Security Requirements

SEC-CONTRACT-001

Security obligations shall be documented.

SEC-CONTRACT-002

Confidentiality requirements shall be established.

SEC-CONTRACT-003

Audit rights shall be considered.

SEC-CONTRACT-004

Incident notification obligations shall be documented.

SEC-CONTRACT-005

Termination requirements shall be defined.

11. Governance Rules

SEC-GOV-076

Third-party assessments shall be mandatory.

SEC-GOV-077

Critical suppliers shall undergo enhanced governance.

SEC-GOV-078

Vendor inventories shall remain current.

SEC-GOV-079

Supply chain security shall be monitored.

SEC-GOV-080

Third-party security activities shall support audit and replay requirements.

12. Metrics

SEC-MET-064

Vendor Assessment Completion

Target: 100%

SEC-MET-065

Critical Vendor Review Compliance

Target: $\geq 95\%$

SEC-MET-066

Vendor Inventory Accuracy

Target: $\geq 98\%$

SEC-MET-067

Supply Chain Review Completion

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-065

Vendor assessments shall be auditable.

AUD-SEC-066

Vendor inventories shall be reviewable.

AUD-SEC-067

Supply chain records shall be retained.

AUD-SEC-068

Third-party governance activities shall support independent verification.

14. Compliance Requirements

Supports:

- SOC 2 Vendor Management
- SOC 2 Security
- ISO 27001 Supplier Relationships
- ISO 27002 Third-Party Security

15. Architectural Constraints

SA-CON-062

Third-party repositories shall support evidence retention.

SA-CON-063

Vendor records shall support traceability.

SA-CON-064

Supply chain governance controls shall preserve audit evidence.

SA-CON-065

Third-party security architecture shall support future ecosystem expansion.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

ENTERPRISE RISK REGISTER

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Vendor compromise
- Dependency vulnerabilities
- Supplier outages
- Third-party data exposure

Mitigation Controls:

- Vendor assessments
- Continuous monitoring
- Supply chain governance
- Contractual controls

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Procurement Team

Governance Office

Engineering Leadership

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- New critical vendors
- Major vendor incidents
- Regulatory changes

20. Section Summary

This section establishes the TODP Third-Party Security, Vendor Risk, and Supply Chain Security Architecture, defining vendor governance requirements, supply chain security controls, monitoring obligations, assessment processes, audit requirements, compliance alignment, and enterprise third-party risk management capabilities.

SECURITY ARCHITECTURE V1

Section 18 – Governance Security Architecture, Decision Integrity & Oversight Controls

Document ID: SEC-SA-018

Document Name: Security Architecture V1

Section ID: SA-18

Section Title: Governance Security Architecture, Decision Integrity & Oversight Controls

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Governance Security Architecture governing security protections applied to governance workflows, governance decisions, approval processes, policy administration, exception management, oversight activities, and security-related governance records within TODP.

The architecture ensures that governance activities remain protected from unauthorized influence, manipulation, circumvention, corruption, or loss while preserving transparency, explainability, traceability, auditability, and replayability.

2. Objectives

- Protect governance decision integrity.
- Secure governance workflows.
- Protect policy administration activities.
- Secure exception management processes.
- Enable accountable decision making.
- Support audit readiness.
- Preserve governance traceability.
- Maintain enterprise governance trust.

3. Scope

Applies to:

- Governance Reviews
- Governance Approvals
- Security Exception Requests
- Policy Management
- Standards Management
- Risk Acceptance Activities
- Compliance Reviews
- Executive Governance Decisions

- Governance Reporting
- Governance Records

4. Governance Security Principles

SEC-GOV-ARCH-001

Governance decisions shall be traceable.

SEC-GOV-ARCH-002

Governance approvals shall be authenticated.

SEC-GOV-ARCH-003

Governance records shall be protected.

SEC-GOV-ARCH-004

Governance actions shall be auditable.

SEC-GOV-ARCH-005

Decision integrity shall be preserved.

SEC-GOV-ARCH-006

Governance controls shall support replay reconstruction.

5. Governance Security Domains

Domain SEC-GOV-DOM-001

Policy Security

Purpose:

Protect governance policies and standards.

Domain SEC-GOV-DOM-002

Approval Security

Purpose:

Protect governance decisions.

Domain SEC-GOV-DOM-003

Exception Security

Purpose:

Protect exception governance.

Domain SEC-GOV-DOM-004

Risk Governance Security

Purpose:

Protect risk acceptance activities.

Domain SEC-GOV-DOM-005

Executive Oversight Security

Purpose:

Protect executive governance decisions.

6. Governance Approval Requirements

SEC-GAPR-001

Approvals shall require authenticated identities.

SEC-GAPR-002

Approvals shall be attributable to approvers.

SEC-GAPR-003

Approval history shall be retained.

SEC-GAPR-004

Approval modifications shall be traceable.

SEC-GAPR-005

Approval records shall be auditable.

7. Security Exception Governance

SEC-EXC-001

Security exceptions shall be documented.

SEC-EXC-002

Exception ownership shall be assigned.

SEC-EXC-003

Exception approvals shall be recorded.

SEC-EXC-004

Exception expiration dates shall be defined.

SEC-EXC-005

Exception reviews shall be conducted periodically.

8. Governance Record Protection

SEC-GREC-001

Governance repositories shall be protected.

SEC-GREC-002

Governance access shall be restricted.

SEC-GREC-003

Governance integrity shall be validated.

SEC-GREC-004

Governance records shall support retention requirements.

SEC-GREC-005

Governance repositories shall support audit reviews.

9. Oversight Security Requirements

SEC-OVR-001

Governance reporting shall be protected.

SEC-OVR-002

Oversight activities shall be logged.

SEC-OVR-003

Governance reviews shall be documented.

SEC-OVR-004

Material governance findings shall be escalated.

SEC-OVR-005

Oversight evidence shall be retained.

10. Governance Workflow Security

SEC-WFLOW-001

Governance workflows shall enforce authorization.

SEC-WFLOW-002

Workflow state changes shall be logged.

SEC-WFLOW-003

Workflow approvals shall be validated.

SEC-WFLOW-004

Workflow evidence shall be retained.

SEC-WFLOW-005

Workflow history shall support replay activities.

11. Governance Rules

SEC-GOV-081

Governance decisions shall be authenticated.

SEC-GOV-082

Governance records shall be protected.

SEC-GOV-083

Security exceptions shall be governed.

SEC-GOV-084

Oversight activities shall be documented.

SEC-GOV-085

Governance security controls shall support audit and replay requirements.

12. Metrics

SEC-MET-068

Governance Approval Traceability

Target: 100%

SEC-MET-069

Exception Review Compliance

Target: $\geq 95\%$

SEC-MET-070

Governance Record Integrity Validation

Target: $\geq 99\%$

SEC-MET-071

Governance Workflow Auditability

Target: 100%

13. Audit Requirements

AUD-SEC-069

Governance approvals shall be auditable.

AUD-SEC-070

Exception records shall be reviewable.

AUD-SEC-071

Governance repositories shall support independent validation.

AUD-SEC-072

Governance workflow histories shall be retained.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Governance Controls
- ISO 27001 Governance Requirements
- ISO 27002 Information Security Governance

15. Architectural Constraints

SA-CON-066

Governance repositories shall support immutable history.

SA-CON-067

Governance workflow records shall preserve traceability.

SA-CON-068

Governance security controls shall preserve audit evidence.

SA-CON-069

Governance architecture shall support future organizational growth.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

DATA GOVERNANCE V1

AI GOVERNANCE FRAMEWORK

PRODUCT GOVERNANCE MODEL

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Governance manipulation
- Unauthorized approvals
- Exception abuse
- Decision integrity failures

Mitigation Controls:

- Authenticated approvals
- Workflow controls
- Governance monitoring
- Audit validation

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Audit Office

Executive Governance Sponsor

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Governance process changes
- Regulatory changes
- Audit findings

20. Section Summary

This section establishes the TODP Governance Security Architecture, defining governance workflow protections, decision integrity controls, approval security requirements, oversight protections, governance record controls, audit obligations, and enterprise governance security capabilities.

SECURITY ARCHITECTURE V1

Section 19 – Audit Security Architecture, Evidence Integrity & Replay Security Framework

Document ID: SEC-SA-019

Document Name: Security Architecture V1

Section ID: SA-19

Section Title: Audit Security Architecture, Evidence Integrity & Replay Security Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section defines the Audit Security Architecture, Evidence Integrity Controls, and Replay Security Framework governing the protection, preservation, verification, reconstruction, and validation of audit and replay capabilities across TODP.

The framework ensures that audit evidence, governance records, system decisions, and replay artifacts remain trustworthy, verifiable, tamper-evident, and available for internal reviews, customer assessments, investigations, compliance activities, and future replay operations.

2. Objectives

- Protect audit evidence integrity.
- Preserve replay reconstruction capability.
- Ensure trustworthy audit records.
- Support forensic investigations.
- Enable independent verification.
- Support compliance obligations.
- Preserve traceability.
- Strengthen enterprise trust.

3. Scope

Applies to:

- Audit Records
- Governance Records
- Replay Records
- Decision Logs
- Recommendation Outputs
- Ranking Artifacts
- Retrieval Artifacts
- Evidence References
- Security Investigation Records
- Compliance Evidence

4. Audit Security Principles

SEC-AUD-ARCH-001

Audit evidence shall be protected.

SEC-AUD-ARCH-002

Replay records shall remain reconstructable.

SEC-AUD-ARCH-003

Audit repositories shall be traceable.

SEC-AUD-ARCH-004

Audit activities shall be independently verifiable.

SEC-AUD-ARCH-005

Evidence integrity shall be continuously protected.

SEC-AUD-ARCH-006

Replay security shall support governance objectives.

5. Audit Security Domains

Domain SEC-AUD-DOM-001

Audit Repository Security

Purpose:

Protect audit evidence.

Domain SEC-AUD-DOM-002

Evidence Integrity Security

Purpose:

Protect evidence trustworthiness.

Domain SEC-AUD-DOM-003

Replay Security

Purpose:

Protect replay processes.

Domain SEC-AUD-DOM-004

Investigation Security

Purpose:

Protect investigation artifacts.

Domain SEC-AUD-DOM-005

Compliance Evidence Security

Purpose:

Protect compliance evidence repositories.

6. Evidence Integrity Requirements

SEC-EINT-001

Evidence integrity validation shall be performed.

SEC-EINT-002

Evidence tampering shall be detectable.

SEC-EINT-003

Evidence repositories shall be protected.

SEC-EINT-004

Integrity validation results shall be retained.

SEC-EINT-005

Integrity controls shall support audits.

7. Replay Security Requirements

SEC-REP-001

Replay inputs shall be protected.

SEC-REP-002

Replay outputs shall be traceable.

SEC-REP-003

Replay execution activities shall be logged.

SEC-REP-004

Replay records shall support historical reconstruction.

SEC-REP-005

Replay repositories shall be protected.

8. Audit Repository Requirements

SEC-AUDREP-001

Audit repositories shall support access controls.

SEC-AUDREP-002

Audit repository changes shall be logged.

SEC-AUDREP-003

Repository integrity shall be validated.

SEC-AUDREP-004

Retention requirements shall be enforced.

SEC-AUDREP-005

Repository reviews shall be conducted periodically.

9. Evidence Access Requirements

SEC-EACC-001

Evidence access shall require authorization.

SEC-EACC-002

Evidence reviews shall be logged.

SEC-EACC-003

Evidence exports shall be governed.

SEC-EACC-004

Evidence sharing shall be approved.

SEC-EACC-005

Evidence access records shall be retained.

10. Investigation Support Requirements

SEC-INVSUP-001

Audit evidence shall support investigations.

SEC-INVSUP-002

Replay evidence shall support investigations.

SEC-INVSUP-003

Evidence chain-of-custody shall be maintained.

SEC-INVSUP-004

Investigation activities shall be documented.

SEC-INVSUP-005

Investigation evidence shall support independent review.

11. Governance Rules

SEC-GOV-086

Audit evidence shall remain protected.

SEC-GOV-087

Replay repositories shall be governed.

SEC-GOV-088

Integrity validation shall be mandatory.

SEC-GOV-089

Evidence access shall be controlled.

SEC-GOV-090

Audit and replay security controls shall support enterprise traceability requirements.

12. Metrics

SEC-MET-072

Evidence Integrity Validation Success Rate

Target: $\geq 99\%$

SEC-MET-073

Replay Reconstruction Success Rate

Target: $\geq 95\%$

SEC-MET-074

Audit Repository Protection Compliance

Target: 100%

SEC-MET-075

Evidence Access Review Completion

Target: $\geq 95\%$

13. Audit Requirements

AUD-SEC-073

Evidence integrity controls shall be auditable.

AUD-SEC-074

Replay records shall be reviewable.

AUD-SEC-075

Audit repositories shall support independent verification.

AUD-SEC-076

Evidence access activities shall be retained.

14. Compliance Requirements

Supports:

- SOC 2 Security
- SOC 2 Processing Integrity
- ISO 27001 Audit Controls
- ISO 27002 Logging and Monitoring Controls

15. Architectural Constraints

SA-CON-070

Audit repositories shall support immutable evidence storage.

SA-CON-071

Replay repositories shall preserve historical records.

SA-CON-072

Evidence integrity controls shall support independent verification.

SA-CON-073

Audit security architecture shall support long-term retention requirements.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

AUDIT MODEL DOCUMENTATION

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Evidence tampering
- Replay corruption
- Audit record loss
- Investigation failures

Mitigation Controls:

- Integrity validation
- Immutable repositories
- Access controls
- Audit monitoring

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Audit Office

Governance Office

Compliance Team

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Audit findings
- Replay architecture changes
- Regulatory updates

20. Section Summary

This section establishes the TODP Audit Security Architecture, Evidence Integrity Controls, and Replay Security Framework, defining audit repository protections, replay security controls, evidence integrity mechanisms, investigation support requirements, governance obligations, audit requirements, and enterprise audit security capabilities.

SECURITY ARCHITECTURE V1

Section 20 – Security Metrics, Continuous Monitoring & Security Performance Management Framework

SECURITY ARCHITECTURE V1

Section 20 – Security Metrics, Continuous Monitoring & Security Performance Management Framework

Document ID: SEC-SA-020

Document Name: Security Architecture V1

Section ID: SA-20

Section Title: Security Metrics, Continuous Monitoring & Security Performance Management Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the Security Metrics, Continuous Monitoring, and Security Performance Management Framework for the Transparent Opportunity Decision Platform (TODP).

The framework defines the measurement methodologies, monitoring controls, reporting mechanisms, governance structures, escalation processes, audit requirements, and performance management practices necessary to evaluate the effectiveness, maturity, efficiency, and operational health of the TODP Security Architecture.

The objective is to provide continuous visibility into security posture, support executive decision-making, enable proactive risk management, maintain audit readiness, and drive ongoing security improvement across all TODP modules and supporting infrastructure.

2. Objectives

- Establish measurable security performance indicators.
- Enable continuous security monitoring.
- Support risk-based decision making.
- Improve security visibility.
- Detect performance degradation.
- Support governance oversight.
- Support compliance and audit requirements.
- Drive continuous security improvement.
- Support enterprise security maturity.
- Maintain operational accountability.

3. Scope

This framework applies to:

- Identity Security
- Access Security
- Application Security
- Data Security
- Infrastructure Security
- Network Security
- Monitoring Operations

- Incident Response
- Vulnerability Management
- Compliance Operations
- Governance Security
- Audit Security
- Replay Security

The framework applies across:

- Opportunity
- Authority
- Evidence
- Retrieval
- Ranking
- Recommendation
- Governance
- Audit
- Replay

4. Security Monitoring Principles

SEC-PERF-001

Security performance shall be measurable.

SEC-PERF-002

Monitoring shall be continuous.

SEC-PERF-003

Metrics shall be evidence-based.

SEC-PERF-004

Monitoring results shall support decision making.

SEC-PERF-005

Performance reporting shall be auditable.

SEC-PERF-006

Monitoring activities shall support continuous improvement.

SEC-PERF-007

Monitoring controls shall preserve replay and traceability requirements.

5. Security Performance Architecture

Layer SEC-PERF-L1

Operational Metrics

Purpose:

Measure day-to-day security activities.

Layer SEC-PERF-L2

Control Effectiveness Metrics

Purpose:

Measure security control performance.

Layer SEC-PERF-L3

Risk Metrics

Purpose:

Measure security risk exposure.

Layer SEC-PERF-L4

Compliance Metrics

Purpose:

Measure regulatory and governance alignment.

Layer SEC-PERF-L5

Executive Metrics

Purpose:

Provide strategic security oversight.

6. Security Metric Categories

Category SEC-MCAT-001

Identity Security Metrics

Examples:

- MFA compliance
- Identity ownership coverage

Category SEC-MCAT-002

Access Security Metrics

Examples:

- Access review completion
- Privileged account compliance

Category SEC-MCAT-003

Application Security Metrics

Examples:

- Security testing coverage
- Vulnerability remediation

Category SEC-MCAT-004

Infrastructure Security Metrics

Examples:

- Hardening compliance
- Monitoring coverage

Category SEC-MCAT-005

Incident Management Metrics

Examples:

- Incident response performance
- Escalation compliance

Category SEC-MCAT-006

Audit & Compliance Metrics

Examples:

- Audit finding closure
- Compliance assessment completion

7. Enterprise Security KPI Framework

SEC-KPI-001

Identity Governance Compliance

Target: 100%

SEC-KPI-002

Privileged Access Review Compliance

Target: $\geq 95\%$

SEC-KPI-003

Security Monitoring Coverage

Target: $\geq 99\%$

SEC-KPI-004

Critical Vulnerability Remediation Compliance

Target: 100%

SEC-KPI-005

Security Incident Documentation Compliance

Target: 100%

SEC-KPI-006

Audit Evidence Completeness

Target: $\geq 98\%$

SEC-KPI-007

Security Assessment Completion

Target: $\geq 95\%$

SEC-KPI-008

Security Control Validation Coverage

Target: $\geq 95\%$

8. Security Dashboard Framework

Dashboard SEC-DASH-001

Executive Security Dashboard

Purpose:

Executive visibility and strategic oversight.

Dashboard SEC-DASH-002

Operational Security Dashboard

Purpose:

Daily security operations management.

Dashboard SEC-DASH-003

Risk Dashboard

Purpose:

Security risk monitoring.

Dashboard SEC-DASH-004

Compliance Dashboard

Purpose:

Compliance and audit readiness.

Dashboard SEC-DASH-005

Incident Dashboard

Purpose:

Incident management visibility.

Dashboard SEC-DASH-006

Audit & Replay Security Dashboard

Purpose:

Audit evidence and replay integrity monitoring.

9. Reporting Framework

Report Type SEC-RPT-001

Operational Security Report

Frequency:

Monthly

Audience:

Security Office

Report Type SEC-RPT-002

Executive Security Report

Frequency:

Quarterly

Audience:

Executive Security Sponsor

Report Type SEC-RPT-003

Security Risk Report

Frequency:

Monthly

Audience:

Governance Committee

Report Type SEC-RPT-004

Compliance Status Report

Frequency:

Quarterly

Audience:

Audit and Compliance Stakeholders

Report Type SEC-RPT-005

Annual Security Maturity Report

Frequency:

Annual

Audience:

Executive Leadership

10. Security Threshold Management

Performance Status

Green

Definition:

Performance within approved thresholds.

Performance Status

Amber

Definition:

Performance below target but within tolerance.

Performance Status

Red

Definition:

Material deviation requiring escalation.

Thresholds shall be formally approved and documented.

11. Escalation Requirements

SEC-ESC-001

Critical security metrics shall be escalated.

SEC-ESC-002

Repeated control failures shall be escalated.

SEC-ESC-003

Material risk increases shall be escalated.

SEC-ESC-004

Persistent compliance deficiencies shall be escalated.

SEC-ESC-005

Executive reporting shall include unresolved security issues.

SEC-ESC-006

Escalation evidence shall be retained.

12. Security Maturity Assessment Framework

Maturity Level 1

Initial

Characteristics:

Reactive security controls.

Maturity Level 2

Managed

Characteristics:

Documented security processes.

Maturity Level 3

Defined

Characteristics:

Standardized security operations.

Maturity Level 4

Measured

Characteristics:

Metric-driven security management.

Maturity Level 5

Optimized

Characteristics:

Continuous improvement and predictive security operations.

Target TODP Security Maturity:

Level 4 progressing toward Level 5.

13. Governance Rules

SEC-GOV-091

Security metrics shall be formally defined.

SEC-GOV-092

Security reporting shall be evidence-based.

SEC-GOV-093

Metric calculations shall be documented.

SEC-GOV-094

Security performance reviews shall occur periodically.

SEC-GOV-095

Monitoring evidence shall be retained.

SEC-GOV-096

Material security deficiencies shall be reported.

SEC-GOV-097

Security performance activities shall support audit and replay requirements.

14. Metrics

SEC-MET-076

Reporting Timeliness

Target: $\geq 95\%$

SEC-MET-077

Metric Accuracy

Target: $\geq 98\%$

SEC-MET-078

Dashboard Availability

Target: $\geq 99\%$

SEC-MET-079

Escalation Compliance

Target: $\geq 95\%$

SEC-MET-080

Security Review Completion

Target: $\geq 95\%$

SEC-MET-081

Security Maturity Assessment Completion

Target: 100%

15. Audit Requirements

AUD-SEC-077

Security metrics shall be auditable.

AUD-SEC-078

Performance reports shall maintain evidence.

AUD-SEC-079

Dashboard data sources shall be traceable.

AUD-SEC-080

Escalation records shall be reviewable.

AUD-SEC-081

Security trend data shall be retained.

AUD-SEC-082

Monitoring controls shall support independent verification.

16. Compliance Requirements

This framework supports alignment with:

- SOC 2 Security Monitoring Requirements
- SOC 2 Governance Requirements
- ISO 27001 Performance Evaluation Controls
- ISO 27001 Management Review Controls
- ISO 27002 Security Measurement Practices
- Enterprise Procurement Reviews

- Customer Security Assessments
- Internal Audit Programs

17. Architectural Constraints

SA-CON-074

Monitoring systems shall remain logically independent from business decision processing.

SA-CON-075

Security metric repositories shall support historical trend analysis.

SA-CON-076

Dashboard services shall integrate with Governance, Audit, and Replay modules.

SA-CON-077

Monitoring architecture shall preserve evidence traceability.

SA-CON-078

Performance records shall support long-term retention requirements.

SA-CON-079

Monitoring architecture shall support future enterprise expansion.

18. Traceability

Related Documents

PRD V1

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

TEST SPEC V1

RTM V1

ADR V1

API SPEC V1

DATA GOVERNANCE V1

Mapped Modules

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

19. Risk Considerations

Primary Risks:

- Security control degradation
- Monitoring blind spots
- Inaccurate reporting
- Delayed risk identification
- Compliance visibility gaps
- Executive oversight deficiencies

Mitigation Controls:

- Continuous monitoring
- KPI governance
- Security dashboards
- Escalation processes
- Maturity assessments
- Independent audits

20. Section Summary

This section establishes the TODP Security Metrics, Continuous Monitoring, and Security Performance Management Framework, defining security KPIs, monitoring controls, reporting mechanisms, maturity assessment models, escalation requirements, governance obligations, audit requirements, compliance expectations, metrics, and architectural constraints necessary to

continuously measure, manage, improve, and demonstrate the effectiveness of the TODP Security Architecture.

SECURITY ARCHITECTURE V1

Section 21 – Security Operating Model, Organizational Structure & Responsibility Framework

Document ID: SEC-SA-021

Document Name: Security Architecture V1

Section ID: SA-21

Section Title: Security Operating Model, Organizational Structure & Responsibility Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the Security Operating Model, Organizational Structure, and Responsibility Framework for the Transparent Opportunity Decision Platform (TODP).

The framework defines the organizational structures, authority boundaries, accountability models, decision rights, operating procedures, escalation paths, and collaboration mechanisms required to execute security governance and operational security activities across TODP.

The objective is to ensure clear ownership, effective oversight, operational accountability, and scalable security governance throughout the platform lifecycle.

2. Objectives

- Establish security organizational governance.
- Define security responsibilities.
- Clarify accountability structures.
- Support enterprise scalability.
- Improve decision-making effectiveness.
- Strengthen security oversight.
- Support audit and compliance activities.
- Reduce operational ambiguity.
- Enable coordinated security operations.
- Maintain enterprise-grade governance.

3. Scope

This framework applies to:

- Security Governance
- Security Operations
- Security Engineering
- Identity Security
- Access Governance
- Application Security
- Infrastructure Security
- Compliance Operations
- Audit Coordination
- Incident Response
- Vendor Security Management

The framework applies across:

- Opportunity
- Authority
- Evidence
- Retrieval
- Ranking
- Recommendation
- Governance
- Audit
- Replay

4. Security Operating Principles

SEC-OPS-001

Security accountability shall be assigned.

SEC-OPS-002

Security decisions shall be traceable.

SEC-OPS-003

Security activities shall be documented.

SEC-OPS-004

Security oversight shall be independent.

SEC-OPS-005

Security operations shall be measurable.

SEC-OPS-006

Security governance shall support continuous improvement.

5. Security Organizational Structure

Level 1

Executive Security Sponsor

Responsibilities:

- Executive oversight
- Strategic security direction
- Risk acceptance authority

Level 2

Security Governance Committee

Responsibilities:

- Policy approval
- Security governance oversight
- Security risk review

Level 3

Security Office

Responsibilities:

- Security architecture ownership
- Security governance administration
- Security reporting

Level 4

Security Domain Owners

Responsibilities:

- Domain control ownership
- Security oversight

Level 5

Operational Security Teams

Responsibilities:

- Daily security operations
- Monitoring
- Incident response

6. Security Governance Committee

Committee ID:

SEC-COM-001

Purpose:

Provide enterprise security oversight.

Membership:

- Executive Security Sponsor
- Security Lead
- Governance Representative
- Audit Representative
- Operations Representative

Responsibilities:

- Security strategy
- Risk review
- Exception approvals
- Program oversight

Meeting Frequency:

Quarterly or as required.

7. Security Office Responsibilities

SEC-OFF-001

Maintain security architecture.

SEC-OFF-002

Maintain security standards.

SEC-OFF-003

Coordinate security reviews.

SEC-OFF-004

Manage security reporting.

SEC-OFF-005

Support audits.

SEC-OFF-006

Manage continuous improvement initiatives.

8. Security Domain Ownership Model

Domain SEC-DOM-011

Identity Security

Domain SEC-DOM-012

Access Security

Domain SEC-DOM-013

Application Security

Domain SEC-DOM-014

Data Security

Domain SEC-DOM-015

Infrastructure Security

Domain SEC-DOM-016

Monitoring & Detection

Domain SEC-DOM-017

Incident Response

Domain SEC-DOM-018

Compliance & Audit

Each domain shall maintain documented ownership.

9. Security Decision Authority Framework

Decision Category

Operational Security Decisions

Authority:

Security Domain Owner

Decision Category

Security Exception Approval

Authority:

Security Governance Committee

Decision Category

Critical Risk Acceptance

Authority:

Executive Security Sponsor

Decision Category

Policy Approval

Authority:

Security Governance Committee

Decision Category

Emergency Security Actions

Authority:

Incident Response Lead

10. Security Escalation Framework

Level 1

Operational Security Team

Level 2

Security Domain Owner

Level 3

Security Office

Level 4

Security Governance Committee

Level 5

Executive Security Sponsor

Escalation criteria shall be documented and auditable.

11. Security Meeting Framework

Meeting Type

Operational Security Review

Frequency:

Monthly

Meeting Type

Risk Review

Frequency:

Monthly

Meeting Type

Security Governance Committee

Frequency:

Quarterly

Meeting Type

Executive Security Review

Frequency:

Quarterly

Meeting Type

Security Audit Readiness Review

Frequency:

Quarterly

12. Governance Rules

SEC-GOV-098

Security responsibilities shall be documented.

SEC-GOV-099

Security authorities shall be assigned.

SEC-GOV-100

Security decisions shall be traceable.

SEC-GOV-101

Security escalations shall be documented.

SEC-GOV-102

Security governance activities shall support audit and replay requirements.

13. Metrics

SEC-MET-082

Security Ownership Coverage

Target: 100%

SEC-MET-083

Security Review Completion

Target: $\geq 95\%$

SEC-MET-084

Security Escalation Resolution Compliance

Target: $\geq 95\%$

SEC-MET-085

Governance Committee Attendance

Target: $\geq 90\%$

14. Audit Requirements

AUD-SEC-083

Security responsibilities shall be auditable.

AUD-SEC-084

Security decisions shall be reviewable.

AUD-SEC-085

Committee records shall be retained.

AUD-SEC-086

Escalation records shall support independent verification.

15. Compliance Requirements

Supports:

- SOC 2 Governance Requirements
- SOC 2 Security Oversight Controls
- ISO 27001 Leadership Controls
- ISO 27001 Organizational Security Controls
- ISO 27002 Governance Practices

16. Architectural Constraints

SA-CON-080

Security governance repositories shall preserve decision history.

SA-CON-081

Security workflow systems shall support approval traceability.

SA-CON-082

Security records shall integrate with Governance, Audit, and Replay modules.

SA-CON-083

Security operating model records shall support historical reconstruction.

17. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

DATA GOVERNANCE V1

AI GOVERNANCE FRAMEWORK

PRODUCT GOVERNANCE MODEL

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Unclear accountability
- Delayed decisions
- Escalation failures
- Governance conflicts

Mitigation Controls:

- Defined ownership
- Escalation framework
- Governance reviews
- Audit validation

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Audit Office

Executive Security Sponsor

20. Section Summary

This section establishes the TODP Security Operating Model, Organizational Structure, and Responsibility Framework, defining security authorities, accountability structures, governance committees, escalation paths, operational responsibilities, audit obligations, and enterprise security oversight mechanisms.

SECURITY ARCHITECTURE V1

Section 22 – Security Risk Management, Risk Governance & Enterprise Security Oversight Framework

Document ID: SEC-SA-022

Document Name: Security Architecture V1

Section ID: SA-22

Section Title: Security Risk Management, Risk Governance & Enterprise Security Oversight Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the Security Risk Management, Risk Governance, and Enterprise Security Oversight Framework for TODP.

The framework defines how security risks are identified, assessed, classified, prioritized, monitored, treated, accepted, escalated, and governed throughout the platform lifecycle.

The objective is to maintain an acceptable security risk posture while supporting transparency, governance, auditability, compliance readiness, and enterprise growth.

2. Objectives

- Establish formal security risk governance.
- Improve risk visibility.
- Support risk-based decision making.
- Reduce security exposure.
- Strengthen executive oversight.
- Improve accountability.
- Support compliance requirements.
- Support audit readiness.
- Enable proactive risk management.
- Maintain enterprise resilience.

3. Scope

This framework applies to:

- Identity Risks
- Access Risks
- Application Risks
- Data Risks
- Infrastructure Risks

- Network Risks
- Third-Party Risks
- Operational Risks
- Compliance Risks
- Governance Risks
- Audit Risks
- Replay Risks

4. Security Risk Management Principles

SEC-RMG-001

Security risks shall be documented.

SEC-RMG-002

Risk ownership shall be assigned.

SEC-RMG-003

Risk decisions shall be traceable.

SEC-RMG-004

Risk treatment shall be monitored.

SEC-RMG-005

Risk acceptance shall be governed.

SEC-RMG-006

Risk activities shall support auditability.

5. Security Risk Categories

Category SEC-RISK-CAT-001

Identity & Access Risk

Category SEC-RISK-CAT-002

Application Security Risk

Category SEC-RISK-CAT-003

Data Protection Risk

Category SEC-RISK-CAT-004

Infrastructure Security Risk

Category SEC-RISK-CAT-005

Operational Security Risk

Category SEC-RISK-CAT-006

Compliance & Governance Risk

Category SEC-RISK-CAT-007

Third-Party Security Risk

Category SEC-RISK-CAT-008

Audit & Replay Risk

6. Risk Assessment Methodology

Likelihood Scale

1 – Rare

2 – Unlikely

3 – Possible

4 – Likely

5 – Almost Certain

Impact Scale

1 – Negligible

2 – Minor

3 – Moderate

4 – Major

5 – Severe

Risk Score

Likelihood × Impact

7. Risk Classification Framework

Low Risk

Score Range:

1 – 4

Medium Risk

Score Range:

5 – 9

High Risk

Score Range:

10 – 16

Critical Risk

Score Range:

17 – 25

8. Risk Treatment Strategies

SEC-TREAT-001

Mitigate

SEC-TREAT-002

Transfer

SEC-TREAT-003

Avoid

SEC-TREAT-004

Accept

All treatment decisions shall be documented.

9. Security Risk Register Requirements

SEC-RISKREG-001

Material risks shall be recorded.

SEC-RISKREG-002

Owners shall be assigned.

SEC-RISKREG-003

Treatment plans shall be maintained.

SEC-RISKREG-004

Risk ratings shall be reviewed.

SEC-RISKREG-005

Historical records shall be retained.

10. Security Oversight Requirements

SEC-OVERSIGHT-001

High and Critical risks shall be reviewed regularly.

SEC-OVERSIGHT-002

Material risks shall be escalated.

SEC-OVERSIGHT-003

Risk reporting shall support executive visibility.

SEC-OVERSIGHT-004

Risk metrics shall be maintained.

SEC-OVERSIGHT-005

Risk governance activities shall be documented.

11. Governance Rules

SEC-GOV-103

Security risks shall be documented.

SEC-GOV-104

Risk ownership shall be assigned.

SEC-GOV-105

Critical risks shall be escalated.

SEC-GOV-106

Risk acceptance shall be approved.

SEC-GOV-107

Risk governance activities shall support audit and replay requirements.

12. Metrics

SEC-MET-086

Risk Register Coverage

Target: 100%

SEC-MET-087

Risk Assessment Completion

Target: $\geq 95\%$

SEC-MET-088

Critical Risk Review Compliance

Target: 100%

SEC-MET-089

Risk Treatment Completion

Target: $\geq 90\%$

13. Audit Requirements

AUD-SEC-087

Risk assessments shall be auditable.

AUD-SEC-088

Risk treatment plans shall be reviewable.

AUD-SEC-089

Risk acceptance decisions shall be retained.

AUD-SEC-090

Risk governance activities shall support independent verification.

14. Compliance Requirements

Supports:

- SOC 2 Risk Assessment
- SOC 2 Security
- ISO 27001 Risk Management
- ISO 27002 Risk Treatment Controls

15. Architectural Constraints

SA-CON-084

Risk repositories shall support historical retention.

SA-CON-085

Risk governance systems shall preserve traceability.

SA-CON-086

Risk records shall support audit evidence requirements.

SA-CON-087

Risk architecture shall support future regulatory obligations.

16. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

ENTERPRISE RISK REGISTER

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Unmanaged risk exposure
- Inadequate oversight
- Delayed remediation
- Poor risk visibility

Mitigation Controls:

- Risk governance
- Executive oversight
- Risk reviews
- Audit validation

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Risk Management Function

Executive Security Sponsor

19. Review Requirements

Review Frequency:

Quarterly

Trigger Events:

- Major incidents
- Material architecture changes
- Regulatory changes

20. Section Summary

This section establishes the TODP Security Risk Management, Risk Governance, and Enterprise Security Oversight Framework, defining risk assessment methodologies, governance structures, treatment strategies, oversight mechanisms, audit obligations, compliance requirements, and enterprise security risk management capabilities.

SECURITY ARCHITECTURE V1

Section 23 – Security Maturity Model, Continuous Improvement & Security Program Evolution Framework

Document ID: SEC-SA-023

Document Name: Security Architecture V1

Section ID: SA-23

Section Title: Security Maturity Model, Continuous Improvement & Security Program Evolution Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the Security Maturity Model, Continuous Improvement, and Security Program Evolution Framework for TODP.

The framework defines the methodology used to evaluate security capability maturity, identify improvement opportunities, prioritize security initiatives, measure program effectiveness, and guide long-term security evolution.

The objective is to ensure that TODP security capabilities continuously mature in alignment with enterprise growth, customer expectations, regulatory requirements, technology changes, governance objectives, and emerging threats.

2. Objectives

- Establish a formal security maturity model.
- Measure security program effectiveness.
- Identify capability gaps.
- Prioritize security improvements.
- Support enterprise scalability.
- Strengthen security governance.
- Improve resilience against emerging threats.
- Support compliance readiness.
- Enable continuous optimization.
- Maintain long-term security excellence.

3. Scope

This framework applies to:

- Security Governance
- Identity Security
- Access Security
- Application Security
- Data Security
- Infrastructure Security
- Network Security
- Monitoring & Detection
- Incident Response
- Vendor Security
- Audit Security
- Replay Security

4. Security Improvement Principles

SEC-IMPR-001

Security improvements shall be evidence-based.

SEC-IMPR-002

Improvements shall be risk-driven.

SEC-IMPR-003

Improvement activities shall be measurable.

SEC-IMPR-004

Security maturity shall be periodically assessed.

SEC-IMPR-005

Lessons learned shall inform improvement priorities.

SEC-IMPR-006

Improvement activities shall support enterprise objectives.

5. Security Maturity Model

Level 1

Initial

Characteristics:

- Ad hoc security activities
- Reactive controls
- Limited governance

Level 2

Managed

Characteristics:

- Documented processes
- Defined ownership
- Basic measurement

Level 3

Defined

Characteristics:

- Standardized controls
- Consistent governance
- Established security operations

Level 4

Measured

Characteristics:

- Metrics-driven management
- Formal risk oversight
- Continuous monitoring

Level 5

Optimized

Characteristics:

- Predictive security operations
- Continuous adaptation
- Advanced automation

Target TODP Security Maturity:

Level 4 progressing toward Level 5.

6. Security Assessment Domains

Domain SEC-MAT-001

Governance Maturity

Domain SEC-MAT-002

Identity & Access Maturity

Domain SEC-MAT-003

Application Security Maturity

Domain SEC-MAT-004

Data Security Maturity

Domain SEC-MAT-005

Infrastructure Security Maturity

Domain SEC-MAT-006

Monitoring & Detection Maturity

Domain SEC-MAT-007

Incident Response Maturity

Domain SEC-MAT-008

Audit & Compliance Maturity

Domain SEC-MAT-009

Replay Security Maturity

7. Security Assessment Requirements

SEC-ASMT-006

Maturity assessments shall occur annually.

SEC-ASMT-007

Assessment criteria shall be documented.

SEC-ASMT-008

Assessment evidence shall be retained.

SEC-ASMT-009

Assessment results shall be reported.

SEC-ASMT-010

Improvement opportunities shall be documented.

8. Continuous Improvement Lifecycle

Stage 1

Assessment

Purpose:

Identify security gaps.

Stage 2

Prioritization

Purpose:

Rank initiatives by risk and value.

Stage 3

Planning

Purpose:

Develop improvement roadmaps.

Stage 4

Execution

Purpose:

Implement approved improvements.

Stage 5

Validation

Purpose:

Verify effectiveness.

Stage 6

Institutionalization

Purpose:

Integrate improvements into standard operations.

9. Improvement Initiative Sources

Improvement opportunities may originate from:

- Security Audits
- Risk Assessments
- Incident Reviews
- Vulnerability Assessments
- Compliance Reviews
- Customer Assessments
- Governance Reviews
- Replay Validation Results
- Security Metrics
- Executive Reviews

10. Security Roadmap Requirements

SEC-RMAP-001

Security roadmaps shall be maintained.

SEC-RMAP-002

Roadmaps shall align with strategic objectives.

SEC-RMAP-003

Roadmaps shall identify accountable owners.

SEC-RMAP-004

Target dates shall be defined.

SEC-RMAP-005

Progress shall be monitored.

11. Lessons Learned Requirements

SEC-LESSON-001

Security incidents shall undergo review.

SEC-LESSON-002

Control failures shall be evaluated.

SEC-LESSON-003

Improvement recommendations shall be documented.

SEC-LESSON-004

Lessons learned shall be retained.

SEC-LESSON-005

Knowledge sharing shall be supported.

12. Governance Rules

SEC-GOV-108

Security maturity assessments shall be performed.

SEC-GOV-109

Improvement initiatives shall be documented.

SEC-GOV-110

Security roadmaps shall be maintained.

SEC-GOV-111

Lessons learned shall be retained.

SEC-GOV-112

Continuous improvement activities shall support audit and replay requirements.

13. Metrics

SEC-MET-090

Security Assessment Completion

Target: 100%

SEC-MET-091

Improvement Initiative Completion

Target: $\geq 90\%$

SEC-MET-092

Roadmap Progress Compliance

Target: $\geq 90\%$

SEC-MET-093

Lessons Learned Review Completion

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-091

Maturity assessments shall be auditable.

AUD-SEC-092

Roadmap records shall be reviewable.

AUD-SEC-093

Improvement initiatives shall support independent verification.

AUD-SEC-094

Lessons learned records shall be retained.

15. Compliance Requirements

Supports:

- SOC 2 Continuous Monitoring
- SOC 2 Governance

- ISO 27001 Continual Improvement
- ISO 27002 Security Improvement Practices

16. Architectural Constraints

SA-CON-088

Improvement repositories shall preserve historical records.

SA-CON-089

Assessment records shall support version history.

SA-CON-090

Improvement tracking systems shall integrate with Governance, Audit, and Replay modules.

SA-CON-091

Security maturity architecture shall support future enterprise growth.

17. Traceability

Related Documents:

BRD V1

SRS V1

SAD V1

TRM V1

DATA GOVERNANCE V1

AI GOVERNANCE FRAMEWORK

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Security stagnation
- Control degradation
- Emerging threats
- Compliance drift

Mitigation Controls:

- Maturity assessments
- Security roadmaps
- Continuous improvement
- Executive oversight

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Audit Office

Engineering Leadership

20. Section Summary

This section establishes the TODP Security Maturity Model, Continuous Improvement, and Security Program Evolution Framework, defining maturity assessment methodologies, improvement lifecycles, roadmap management practices, governance requirements, audit obligations, and enterprise security optimization mechanisms.

Section 24 – Security Documentation Governance, Document Control & Knowledge Management Framework

Document ID: SEC-SA-024

Document Name: Security Architecture V1

Section ID: SA-24

Section Title: Security Documentation Governance, Document Control & Knowledge Management Framework

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the Security Documentation Governance, Document Control, and Knowledge Management Framework for TODP.

The framework defines how security documentation is created, reviewed, approved, maintained, protected, archived, and retired throughout its lifecycle.

The objective is to ensure that all security knowledge, security standards, procedures, evidence, architectural decisions, and governance records remain accurate, controlled, traceable, auditable, and available to authorized stakeholders.

2. Objectives

- Establish security document governance.
- Ensure document accuracy and consistency.
- Maintain version control.

- Support audit readiness.
- Preserve organizational knowledge.
- Improve security transparency.
- Support compliance obligations.
- Enable long-term documentation sustainability.
- Protect security-sensitive information.
- Support enterprise growth.

3. Scope

Applies to:

- Security Policies
- Security Standards
- Security Procedures
- Security Architecture Documents
- Security Runbooks
- Security Reports
- Security Audit Records
- Security Risk Registers
- Security Assessment Reports
- Security Training Materials
- Security Evidence Repositories

4. Documentation Governance Principles

SEC-DOC-001

Security documents shall have assigned owners.

SEC-DOC-002

Security documents shall be version controlled.

SEC-DOC-003

Document approvals shall be recorded.

SEC-DOC-004

Document reviews shall be performed periodically.

SEC-DOC-005

Security documentation shall be protected.

SEC-DOC-006

Document governance shall support auditability.

5. Security Document Categories

Category SEC-DOC-CAT-001

Policies

Category SEC-DOC-CAT-002

Standards

Category SEC-DOC-CAT-003

Procedures

Category SEC-DOC-CAT-004

Architecture Documents

Category SEC-DOC-CAT-005

Runbooks

Category SEC-DOC-CAT-006

Audit & Compliance Records

Category SEC-DOC-CAT-007

Risk & Governance Records

6. Document Lifecycle Framework

Stage 1

Draft

Stage 2

Review

Stage 3

Approval

Stage 4

Publication

Stage 5

Maintenance

Stage 6

Archive

Stage 7

Retirement

7. Document Ownership Requirements

SEC-DOC-OWN-001

Each document shall have a designated owner.

SEC-DOC-OWN-002

Owners shall maintain document accuracy.

SEC-DOC-OWN-003

Ownership changes shall be documented.

SEC-DOC-OWN-004

Ownership records shall be retained.

8. Version Control Requirements

SEC-VER-001

Version history shall be maintained.

SEC-VER-002

Material changes shall be documented.

SEC-VER-003

Document revisions shall be traceable.

SEC-VER-004

Historical versions shall be retained.

9. Knowledge Management Requirements

SEC-KM-001

Security knowledge repositories shall be maintained.

SEC-KM-002

Approved guidance shall be accessible to authorized users.

SEC-KM-003

Knowledge updates shall be documented.

SEC-KM-004

Knowledge retention requirements shall be enforced.

10. Review & Maintenance Requirements

SEC-REV-005

Security policies shall be reviewed annually.

SEC-REV-006

Architecture documents shall be reviewed annually.

SEC-REV-007

Material changes shall trigger reviews.

SEC-REV-008

Review evidence shall be retained.

11. Governance Rules

SEC-GOV-113

Security documents shall be governed.

SEC-GOV-114

Version control shall be mandatory.

SEC-GOV-115

Document ownership shall be assigned.

SEC-GOV-116

Review schedules shall be maintained.

SEC-GOV-117

Documentation activities shall support audit and replay requirements.

12. Metrics

SEC-MET-094

Document Ownership Coverage

Target: 100%

SEC-MET-095

Review Completion Compliance

Target: $\geq 95\%$

SEC-MET-096

Version Control Compliance

Target: 100%

SEC-MET-097

Document Approval Compliance

Target: 100%

13. Audit Requirements

AUD-SEC-095

Document histories shall be auditable.

AUD-SEC-096

Approval records shall be reviewable.

AUD-SEC-097

Ownership assignments shall be verifiable.

AUD-SEC-098

Review evidence shall support independent validation.

14. Compliance Requirements

Supports:

- SOC 2 Documentation Controls
- SOC 2 Governance Requirements
- ISO 27001 Documented Information Controls
- ISO 27002 Security Documentation Practices

15. Architectural Constraints

SA-CON-092

Document repositories shall support version history.

SA-CON-093

Knowledge repositories shall support controlled access.

SA-CON-094

Documentation systems shall preserve audit evidence.

SA-CON-095

Documentation architecture shall support future enterprise expansion.

16. Traceability

Related Documents:

PRD V1

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

DATA GOVERNANCE V1

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

17. Risk Considerations

Primary Risks:

- Outdated documentation
- Missing ownership
- Inaccurate guidance
- Knowledge loss

Mitigation Controls:

- Version control
- Review processes
- Ownership assignments
- Knowledge repositories

18. Ownership

Primary Owner:

Security Office

Supporting Owners:

Governance Office

Audit Office

Document Owners

19. Review Requirements

Review Frequency:

Annual

Trigger Events:

- Major security changes
- Regulatory changes
- Audit findings

20. Section Summary

This section establishes the TODP Security Documentation Governance, Document Control, and Knowledge Management Framework, defining document lifecycle processes, ownership responsibilities, version control requirements, knowledge management practices, governance obligations, audit requirements, and enterprise documentation controls.

SECURITY ARCHITECTURE V1

Section 25 – Security Architecture Governance, Strategic Security Vision & Architecture Roadmap

Document ID: SEC-SA-025

Document Name: Security Architecture V1

Section ID: SA-25

Section Title: Security Architecture Governance, Strategic Security Vision & Architecture Roadmap

Version: 1.0

Status: Approved

Owner: Security Office

Classification: Internal Confidential

1. Purpose

This section establishes the long-term Security Architecture Governance Model, Strategic Security Vision, and Security Architecture Roadmap for the Transparent Opportunity Decision Platform (TODP).

The framework defines how the security architecture shall evolve, be governed, reviewed, improved, measured, and aligned with business objectives, technology strategy, enterprise customer requirements, compliance obligations, risk management objectives, and organizational growth.

The purpose of this section is to ensure that TODP maintains a sustainable, scalable, auditable, and enterprise-ready security architecture capable of supporting future platform expansion while preserving transparency, explainability, traceability, governance, auditability, and replayability.

2. Objectives

- Establish long-term security architecture governance.
- Define strategic security direction.
- Support enterprise-scale growth.
- Maintain alignment with business strategy.
- Support customer trust and procurement reviews.
- Enable future compliance certifications.
- Strengthen security resilience.
- Support secure innovation.

- Maintain security architecture consistency.
- Enable continuous architectural improvement.

3. Scope

This framework applies to:

- Security Governance
- Security Architecture
- Security Controls
- Security Operations
- Security Monitoring
- Security Risk Management
- Security Compliance
- Security Audit Programs
- Security Documentation
- Security Tooling
- Security Reporting
- Security Roadmaps

The framework applies across:

- Opportunity
- Authority
- Evidence
- Retrieval
- Ranking

- Recommendation
- Governance
- Audit
- Replay

4. Strategic Security Vision

TODP shall maintain a security architecture that is:

- Secure by Design
- Governed by Policy
- Auditable by Default
- Traceable by Default
- Replayable by Design
- Continuously Monitored
- Risk-Driven
- Compliance-Aligned
- Enterprise Scalable
- Operationally Resilient

The security architecture shall support enterprise customers, future certifications, regulatory requirements, and long-term platform sustainability.

5. Security Architecture Governance Model

Governance Layer 1

Security Control Governance

Purpose:

Manage security control effectiveness.

Governance Layer 2

Security Risk Governance

Purpose:

Manage enterprise security risks.

Governance Layer 3

Security Compliance Governance

Purpose:

Maintain compliance alignment.

Governance Layer 4

Security Audit Governance

Purpose:

Maintain assurance and validation.

Governance Layer 5

Executive Security Governance

Purpose:

Provide strategic oversight.

6. Security Architecture Decision Framework

SEC-ARCH-DEC-001

Security architecture decisions shall be documented.

SEC-ARCH-DEC-002

Material architectural changes shall undergo review.

SEC-ARCH-DEC-003

Security impacts shall be assessed before approval.

SEC-ARCH-DEC-004

Decision rationale shall be retained.

SEC-ARCH-DEC-005

Architectural decisions shall support traceability.

SEC-ARCH-DEC-006

Architecture decisions shall preserve replay requirements.

7. Security Architecture Review Framework

Review Type

Operational Security Review

Frequency:

Quarterly

Review Type

Architecture Review

Frequency:

Semi-Annual

Review Type

Risk Alignment Review

Frequency:

Quarterly

Review Type

Compliance Alignment Review

Frequency:

Annual

Review Type

Executive Security Strategy Review

Frequency:

Annual

8. Security Architecture Roadmap

Phase 1

Foundational Security

Objectives:

- Core security controls
- Governance establishment
- Audit readiness

Phase 2

Enterprise Security Expansion

Objectives:

- Enhanced monitoring
- Advanced governance
- Security automation

Phase 3

Compliance & Certification Readiness

Objectives:

- SOC 2 readiness
- ISO 27001 readiness

- Customer procurement readiness

Phase 4

Security Optimization

Objectives:

- Advanced analytics
- Security orchestration
- Predictive monitoring

Phase 5

Adaptive Security Architecture

Objectives:

- Continuous improvement
- Threat-adaptive controls
- Security maturity optimization

9. Security Innovation Governance

SEC-INNOV-001

Security innovation shall align with governance requirements.

SEC-INNOV-002

New technologies shall undergo security review.

SEC-INNOV-003

Security impacts shall be documented.

SEC-INNOV-004

Innovation risks shall be assessed.

SEC-INNOV-005

Innovation activities shall preserve security principles.

10. Enterprise Security Alignment Requirements

SEC-ALIGN-001

Security strategy shall align with business objectives.

SEC-ALIGN-002

Security architecture shall align with product strategy.

SEC-ALIGN-003

Security investments shall be risk-informed.

SEC-ALIGN-004

Security initiatives shall support enterprise growth.

SEC-ALIGN-005

Security planning shall support customer requirements.

11. Future-State Security Architecture Objectives

Future Objective SEC-FUTURE-001

Advanced Security Analytics

Future Objective SEC-FUTURE-002

Security Automation

Future Objective SEC-FUTURE-003

Continuous Compliance Monitoring

Future Objective SEC-FUTURE-004

Advanced Threat Detection

Future Objective SEC-FUTURE-005

Security Orchestration

Future Objective SEC-FUTURE-006

Expanded Audit Intelligence

Future Objective SEC-FUTURE-007

Enhanced Replay Integrity Controls

Future Objective SEC-FUTURE-008

Enterprise Security Maturity Level 5

12. Governance Rules

SEC-GOV-118

Security architecture shall be governed.

SEC-GOV-119

Architecture reviews shall be performed.

SEC-GOV-120

Strategic security objectives shall be maintained.

SEC-GOV-121

Architecture roadmaps shall be reviewed periodically.

SEC-GOV-122

Material architecture changes shall be documented.

SEC-GOV-123

Architecture governance activities shall support audit requirements.

SEC-GOV-124

Architecture governance activities shall support replay requirements.

13. Metrics

SEC-MET-098

Architecture Review Completion

Target: $\geq 95\%$

SEC-MET-099

Strategic Initiative Completion

Target: $\geq 90\%$

SEC-MET-100

Security Roadmap Progress

Target: $\geq 90\%$

SEC-MET-101

Architecture Decision Documentation Coverage

Target: 100%

SEC-MET-102

Security Governance Compliance

Target: $\geq 95\%$

14. Audit Requirements

AUD-SEC-099

Architecture decisions shall be auditable.

AUD-SEC-100

Roadmap activities shall be reviewable.

AUD-SEC-101

Strategic reviews shall be documented.

AUD-SEC-102

Governance activities shall support independent verification.

AUD-SEC-103

Architecture review evidence shall be retained.

15. Compliance Requirements

This framework supports alignment with:

- SOC 2 Security

- SOC 2 Governance
- SOC 2 Risk Management
- ISO 27001 Information Security Management
- ISO 27001 Continual Improvement
- ISO 27002 Security Governance
- Enterprise Procurement Reviews
- Customer Security Assessments
- Future Certification Programs

16. Architectural Constraints

SA-CON-096

Security architecture shall preserve transparency principles.

SA-CON-097

Security architecture shall preserve explainability principles.

SA-CON-098

Security architecture shall preserve traceability principles.

SA-CON-099

Security architecture shall preserve governance requirements.

SA-CON-100

Security architecture shall preserve auditability requirements.

SA-CON-101

Security architecture shall preserve replayability requirements.

SA-CON-102

Security architecture evolution shall maintain backward governance compatibility.

SA-CON-103

Security architecture repositories shall support long-term retention.

17. Traceability

Related Documents:

PRD V1

BRD V1

SRS V1

SAD V1

TDD V1

TRM V1

TEST SPEC V1

RTM V1

ADR V1

API SPEC V1

DATA GOVERNANCE V1

COMPLIANCE PACKAGE V1

AI GOVERNANCE FRAMEWORK

ENTERPRISE RISK REGISTER

PRODUCT GOVERNANCE MODEL

Mapped Modules:

Opportunity

Authority

Evidence

Retrieval

Ranking

Recommendation

Governance

Audit

Replay

18. Risk Considerations

Primary Risks:

- Architectural drift
- Security control obsolescence

- Compliance misalignment
- Strategic execution failures
- Governance fragmentation
- Technology evolution risks

Mitigation Controls:

- Architecture governance
- Strategic reviews
- Roadmap management
- Continuous improvement
- Executive oversight
- Audit validation

19. Ownership

Primary Owner:

Security Office

Supporting Owners:

Executive Security Sponsor

Governance Office

Audit Office

Compliance Team

Enterprise Architecture Function

20. Section Summary

This section establishes the TODP Security Architecture Governance Model, Strategic Security Vision, and Security Architecture Roadmap, defining long-term governance structures, architectural decision controls, strategic objectives, roadmap planning requirements, future-state security capabilities, audit obligations, compliance alignment, and enterprise security evolution principles necessary to sustain TODP as a secure, scalable, auditable, and enterprise-ready platform.

END OF SECURITY ARCHITECTURE V1

Document Status: Complete

Total Sections: 25

Architecture Domains Covered:

Identity Security

Access Security

Data Security

Application Security

Infrastructure Security

Network Security

Monitoring & Detection

Incident Response

Risk Management

Compliance

Audit Security

Replay Security

Governance Security

Business Continuity

Vendor Security

Security Operations

Security Performance Management

Security Architecture Governance

Traceability Status:

Aligned with BRD V1, SRS V1, SAD V1, TDD V1, TRM V1, TEST SPEC V1, RTM V1, ADR V1, API SPEC V1, DATA GOVERNANCE V1, AI GOVERNANCE FRAMEWORK, PRODUCT GOVERNANCE MODEL, ENTERPRISE RISK REGISTER, and TODP Core Architecture.